

MALICIOUSSKILLBENCH: A COMPREHENSIVE BENCHMARK FOR MALICIOUS AGENT SKILL DETECTION

Yue Wang¹ Yi Liu² Gelei Deng³ Ying Zhang⁴ Yuekang Li⁵ Zhenyu Chen¹ Leo Zhang²

¹State Key Laboratory for Novel Software Technology, Nanjing University

²Griffith University ³Nanyang Technological University ⁴Wake Forest University

⁵University of New South Wales

ABSTRACT

Agent Skills extend LLM agents with reusable instruction packages that may also include scripts, resources, and service configuration. This creates a direct distribution channel for malicious behavior, yet existing malicious-Skill datasets are fragmented across sources, artifact formats, evidence regimes, and benign coverage; duplicated and structurally related content further complicates direct aggregation and evaluation. We present MALICIOUSSKILLBENCH, a comprehensive benchmark for malicious Agent Skill detection. We consolidate 13 public sources, 11 of which contribute Core malicious artifacts, and reduce 8,414 raw malicious records to 7,539 normalized-unique identities in 4,588 operational structural families. After conservative cross-label conflict exclusion, the primary benchmark contains **9,740 Skills: 7,505 malicious and 2,235 benign**. To characterize its coverage, we harmonize **11 attack categories** for 4,983 malicious identities with supported source-native mappings and find substantial differences in threat composition across sources. We then evaluate three learned text detectors and three off-the-shelf Skill scanners. Learned detectors achieve 0.882–0.932 Random Macro-F1 but only 0.653–0.665 under Source-Disjoint evaluation; the strongest word TF-IDF SVM scores **0.932/0.916/0.665** on Random/structural-disjoint/Source-Disjoint while retaining 95.6% malicious recall but producing 62.4% benign FPR on held-out sources. Off-the-shelf scanners occupy different but also unsatisfactory operating regimes, reducing false positives only at the cost of sharply lower malicious recall. Together, these results show that reliable malicious-Skill detection requires both broader cross-source benchmark coverage and evaluation that jointly measures attack detection and benign over-flagging. **Resources:** [Project Page](#).

1 INTRODUCTION

Large language model (LLM) agents increasingly acquire reusable capabilities through *Skills*: installable packages that combine natural-language instructions with scripts, templates, resources, and service configuration. A malicious Skill can therefore act as trusted procedural authority inside the agent’s workflow. Recent studies show that malicious Skills can steal credentials, manipulate agent behavior, introduce triggered backdoors, or conceal unsafe side effects (Guo et al., 2026; Zhuang et al., 2026; Liu et al., 2026a; Feng et al., 2026). This makes pre-installation malicious-Skill detection an increasingly important security problem.

The available datasets do not yet provide a single, reliable basis for studying that problem. Existing Skill-security resources were created for different purposes and release different objects: complete Skill artifacts, constructed attack variants, runtime-verified cases, vulnerability records, marketplace observations, or scanner-derived signals (Guo et al., 2026; Zhuang et al., 2026; Liu et al., 2026a; Ning et al., 2026; Jin et al., 2026). Their labels are supported by different mixtures of construction, human review, runtime verification, static analysis, and automated scanning, and their benign coverage is uneven. Sources also overlap: identical or formatting-equivalent Skills recur across datasets, related variants reuse common scaffolds, and the same normalized content can receive conflicting labels. Simply concatenating published rows therefore overstates independent coverage and can produce misleading evaluation splits.

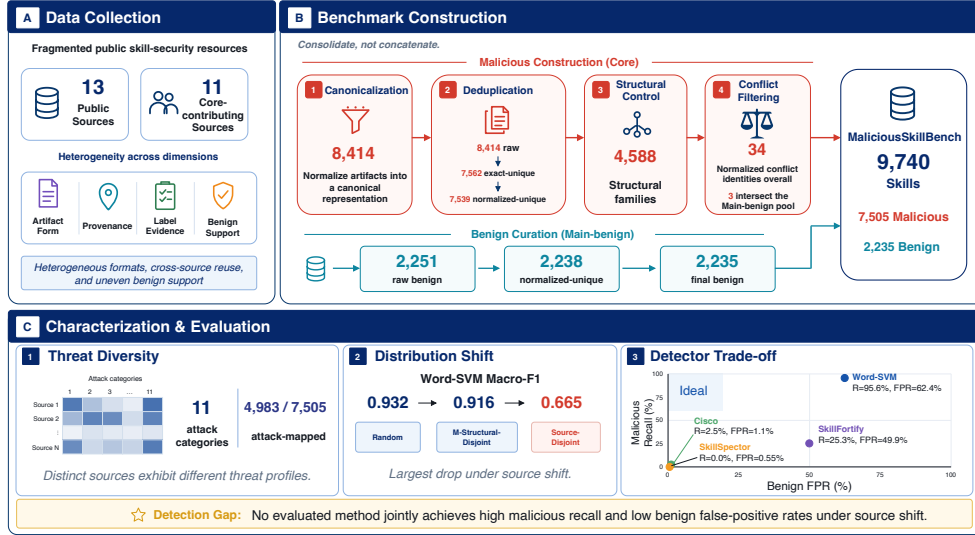


Figure 1: Overview of MALICIOUSSKILLBENCH. (A) Fragmented sources differ in artifacts, provenance, evidence, and benign support. (B) Controlled canonicalization, deduplication, structural grouping, benign curation, and conflict filtering yield 9,740 normalized-unique Skills (7,505 malicious; 2,235 benign). (C) Characterization and held-out-source evaluation expose heterogeneous attack coverage and distinct detector recall/FPR regimes; the source–attack matrix is schematic (quantitative results in Figure 2).

We build MALICIOUSSKILLBENCH to turn this fragmented landscape into a common detection benchmark. Here, *comprehensive* refers to broad, traceable cross-source consolidation of Skill artifacts from 13 frozen public sources. We freeze 13 public sources and retain 11 that satisfy a conservative Core-malicious artifact rule. We canonicalize heterogeneous records while preserving source and evidence semantics, deduplicate exact and formatting-equivalent content, model broader structural reuse separately from attack semantics, and exclude cross-label conflicts before evaluation. The resulting benchmark contains **9,740 normalized-unique Skills: 7,505 malicious and 2,235 benign**. Its malicious side originates from 8,414 raw Core artifacts, which reduce to 7,562 exact-unique and 7,539 normalized-unique identities organized into 4,588 operational structural families.

The consolidated benchmark also makes it possible to ask what malicious behavior existing resources actually cover. Using only documented source-native labels and deterministic strong-semantic mappings, we harmonize **11 attack categories for 4,983 of the 7,505 malicious identities**. Their distributions differ sharply across sources, so individual datasets emphasize different slices of the threat landscape.

Finally, MALICIOUSSKILLBENCH changes the conclusion one would draw about detector performance. Across three learned static text baselines, Random Macro-F1 is **0.882–0.932**, but Source-Disjoint Macro-F1 falls to **0.653–0.665**. The strongest word TF–IDF SVM scores **0.932/0.916/0.665** under Random, malicious-structural-disjoint, and Source-Disjoint evaluation. On held-out sources it still detects 95.6% of malicious Skills, yet flags 62.4% of benign Skills as malicious: malicious recall remains high while benign over-flagging dominates. Three off-the-shelf Skill-security scanners reveal the opposite failure regime: configurations with very low benign false-positive rates detect only a small fraction of malicious Skills, while the more sensitive scanner incurs substantial benign false positives. No evaluated detector simultaneously achieves high malicious recall and low benign FPR across held-out sources.

Our contributions are:

- **A comprehensive malicious-Skill detection benchmark.** We consolidate 13 public sources into a traceable artifact-level resource, preserving heterogeneous evidence while controlling exact/normalized duplication, structural reuse, and cross-label conflicts; the frozen primary benchmark contains 9,740 Skills.

- **A source-aware threat characterization.** We harmonize 11 attack categories for the supported mapped subset and quantify source, provenance, attack, and derived-impact coverage, revealing substantial heterogeneity across existing resources.
- **A unified evaluation of learned and off-the-shelf detectors.** Random, structural-disjoint, and source-disjoint tests reveal substantial cross-source degradation despite strong random-split scores: learned models over-flag unfamiliar benign Skills, while current scanners reduce false positives largely by sacrificing malicious recall.

2 BACKGROUND AND RELATED WORK

2.1 AGENT AND TOOL SECURITY

Tool-using agents inherit security failures from untrusted observations, tool interfaces, and persistent state. InjecAgent and AgentDojo established indirect prompt injection in realistic tool-mediated workflows, while Agent Security Bench broadened evaluation to attacks on prompts, tools, and memory (Zhan et al., 2024; Debenedetti et al., 2024; Zhang et al., 2024). More recent MCP studies show that even tool metadata can become an attack channel (Wang et al., 2025). Agent Skills create a related but distinct trust boundary: the Skill itself is installed as reusable procedural authority and may combine instructions, helper code, resources, and permissions. This creates a distinct security question about the trustworthiness of an installed capability package before it becomes reusable procedural authority.

2.2 SKILL-SPECIFIC THREATS, DATASETS, AND DEFENSES

Recent work studies complementary parts of the Skill attack surface. Skill-Inject evaluates prompt injections carried by Skill files, SkillTrojan studies triggered backdoors, and SkillSafetyBench and SkillHarm study Skill-mediated unsafe behavior and harmful capability use (Schmotz et al., 2026; Feng et al., 2026; Jin et al., 2026; Ning et al., 2026). Large-scale empirical studies also characterize marketplace-scale Skill vulnerabilities and credential leakage (Liu et al., 2026b; Chen et al., 2026). Artifact-oriented datasets cover other parts of the space: Liu et al. (2026a) behaviorally verifies marketplace samples; AgentTrap evaluates complete runtime trajectories; and MalSkillBench combines generated runtime-verified attacks, wild samples, and matched benign Skills (Zhuang et al., 2026; Guo et al., 2026). Scanner-oriented resources use still different supervision: ClawHub Security Signals releases a large silver-standard marketplace snapshot, SkillTrustBench separates normal, suspicious, and malicious cases for scanner evaluation, and SkillFortifyBench provides a deterministic multi-format synthetic testbed (Koc et al., 2026; Tencent Zhuque Lab and CUHK-Shenzhen, 2026; Bhardwaj, 2026).

Defenses are similarly heterogeneous. RouteGuard uses internal model signals for pre-execution poisoning detection, Locate-and-Judge uses attention to scale marketplace triage, SkillGate combines lexical prefiltering with LLM judgment, and Runtime Skill Audit and SkillDetonate move toward behavior-centric execution-time evidence (Xiao et al., 2026; Etteib et al., 2026; Yang et al., 2026; Lan and Xiao, 2026; Ji et al., 2026). Other work exposes blind spots beyond plain text, including compositional risk among individually safe Skills and malicious instructions hidden in visual resources (Wang et al., 2026; Jia et al., 2026). ColluSkill further studies adversarial cross-Skill composition and reports that harmful workflows can evade scanners that inspect Skills individually (Zeng et al., 2026). MALICIOUSSKILLBENCH is complementary to these attack and defense proposals by consolidating heterogeneous public resources into a common artifact-level detection benchmark and evaluating both learned and off-the-shelf detectors under the same frozen data contract.

2.3 BENCHMARK ARTIFACTS AND DISTRIBUTION SHIFT

A broader benchmark literature shows why this consolidation must control both duplication and domain-specific shortcuts. Annotation artifacts can make labels predictable from unintended cues (Gururangan et al., 2018); WILDS demonstrates degradation under naturally occurring distribution shifts, and DomainBed shows that domain-generalization conclusions depend strongly on standardized evaluation protocols (Koh et al., 2021; Gulrajani and Lopez-Paz, 2021). We use source identity and construction provenance for audit and stratification and exclude them from detector features.

Our held-out-source evaluation measures source-conditioned stress under coupled source factors; normalized deduplication, malicious-structural-disjoint evaluation, class balancing, and scaffold sanitization probe distinct shortcut channels.

3 WHY A COMPREHENSIVE BENCHMARK?

Existing malicious-Skill datasets were built under different assumptions and cannot be treated as interchangeable rows. Our 13-source registry exposes four concrete deficiencies that a detection benchmark must address.

Existing coverage is fragmented. Prior work studies complementary slices of the Skill threat surface: generated and runtime-verified malicious artifacts, in-the-wild marketplace samples, triggered backdoors, harmful capability use, vulnerability records, and scanner-oriented resources (Guo et al., 2026; Zhuang et al., 2026; Liu et al., 2026a; Feng et al., 2026; Ning et al., 2026; Jin et al., 2026). Their released units and labels are not equivalent. A complete Skill artifact supported by runtime evidence is a different observation from a vulnerability record or an automated scanner verdict. A comprehensive benchmark must reconcile these resources without erasing source, artifact, provenance, or evidence semantics.

More rows do not necessarily mean more independent coverage. In the frozen collection, 8,414 Core malicious records reduce to 7,562 exact-unique and 7,539 normalized-unique Skill contents. Broader static similarity further partitions the malicious side into 4,588 operational structural families, while 34 normalized identities collide across malicious and benign labels. These are different phenomena—content identity, scaffold reuse, and label inconsistency—and they require different controls. Simply concatenating all rows would inflate apparent scale and can place reused content on both sides of a split.

Detection also requires credible benign data. The source registry is strongly asymmetric: several resources contain malicious Skills only, and benign labels vary in strength. After conservative eligibility and conflict exclusion, the primary benchmark contains 7,505 malicious and 2,235 Main-benign normalized-unique Skills. This matters operationally because source, construction procedure, and class composition are coupled. A detector can achieve high apparent attack coverage simply by broadly flagging unfamiliar artifacts. Evaluating deployable detection therefore requires high-confidence benign examples from multiple source conventions.

Random splits are an incomplete test of deployment robustness. Random splitting is useful as a reference, but it can distribute source conventions and structurally related variants across train and test. Cross-domain benchmark practice similarly distinguishes in-distribution accuracy from performance under domain shift (Koh et al., 2021; Gulrajani and Lopez-Paz, 2021). For malicious Skills, source identity bundles collection venue, attack construction, documentation style, labeling policy, provenance, and benign population. We therefore need complementary views of difficulty: random evaluation, malicious structural-family disjointness, and held-out-source evaluation. The last measures source-conditioned stress under coupled source factors.

These deficiencies translate directly into the design of MALICIOUSKILLBENCH: a common artifact-level unit, evidence-preserving canonicalization, explicit identity/reuse/conflict control, a high-confidence benign pool, and evaluation protocols that distinguish conventional random performance from structural and source-conditioned generalization. Section 4 describes the construction pipeline.

4 BUILDING MALICIOUSKILLBENCH

We construct MALICIOUSKILLBENCH with four consolidation stages (Figure 1): qualify source artifacts, map records into an evidence-preserving schema, control identity and structural reuse, and finalize the detection set after conflict exclusion. Detailed controlled vocabularies, lineage records, and release rules are deferred to the appendix.

4.1 SOURCE COLLECTION AND ARTIFACT ELIGIBILITY

Collect broadly, qualify conservatively. We freeze 13 public malicious-Skill datasets and security corpora and record source revision, license, redistribution status, reported/acquired counts, and artifact availability. Across all benchmark roles, the canonical manifest contains 182,699 records. A source contributes to the Core malicious benchmark only when we can recover an actual Skill artifact, preserve the source-native malicious claim and its supporting evidence, keep the artifact inert as detector input, and trace it to a frozen source revision. Security-relevant task pairs, vulnerability-only rows, scanner verdicts, environment fixtures, and non-Skill configurations are retained as Auxiliary under their original source semantics.

Eleven of the 13 sources satisfy this Core rule (Table 1), contributing **8,414 raw malicious Skill artifacts**. Their provenance spans wild, test-fixture, injected/backdoored, and synthetic collections, and their benign support is highly uneven. This heterogeneity is retained so later analyses can distinguish what was observed, constructed, or inferred.

Table 1: Coverage of the 11 Core-contributing sources in the frozen benchmark. “Norm.” reports per-source normalized-unique malicious identities and therefore need not sum to 7,539 because identities can occur in multiple sources; Main-benign counts precede conflict exclusion.

Source	Core raw	Norm.	Main benign	Core provenance
MalSkillBench	3,944	3,430	0	mixed/unresolved
MaliciousAgentSkillsBench	157	157	0	wild
SkillLeakBench	79	67	0	wild
Agent Skill Malware	124	124	0	wild
AgentTrap	91	89	50	test fixture
SkillTrojan	1	1	2	backdoored
SkillHarm	879	739	0	injected/backdoored
SkillTrustBench	2,863	2,861	1,643	injected/synth./wild
ATR Skill Security	32	29	466	wild/test fixture
SkillFortifyBench	90	90	90	synthetic
SkillSafetyBench	154	154	0	injected

Recover missing artifacts without relaxing eligibility. Two sources require a documented acquisition exception. The public releases of SRC002 (*MaliciousAgentSkillsBench*) and SRC004 (*SkillLeakBench*) (Chen et al., 2026) provide study metadata/labels but not the raw malicious Skill artifacts needed for our static benchmark. We keep those public revisions as the source of record and link eligible rows to author-provided historical research snapshots, recovering **157 SRC002** and **79 SRC004** malicious artifacts under the same Core rule. Four unresolved SRC004 multi-Skill cases and its vulnerability-only records remain outside Core. Benchmark membership and redistribution permission are tracked separately.

4.2 CANONICALIZATION WITHOUT ERASING EVIDENCE

Every acquired record receives a stable canonical ID while retaining source ID, source label, source revision, artifact type, provenance, label strength, evidence type, hashes, and available lineage metadata. Source-specific labels are mapped conservatively: a record supported only as *vulnerable*, *suspicious*, dual-use, or scanner-flagged is not upgraded to malicious ground truth, and unresolved provenance or parentage remains unresolved. The complete vocabulary records intent, provenance, and evidence as distinct fields (Appendix B).

This common schema prevents source-native row count, variant count, and independent content identity from being conflated. Published base/variant links are retained when explicit; similarity is used only for structural reuse analysis and never establishes causal lineage. Throughout acquisition and canonicalization, potentially malicious artifacts are handled as inert static data: the pipeline copies or parses text and metadata but does not execute Skill code, helpers, payloads, URLs, installers, or embedded instructions.

4.3 DEDUPLICATION AND STRUCTURAL REUSE CONTROL

We separate three forms of relatedness because they answer different benchmark questions. *Exact identity* is SHA-256 equality over acquired Skill content. *Normalized identity* applies deterministic conservative text normalization to collapse formatting-equivalent content while preserving substantive text. These stages reduce **8,414 raw Core malicious artifacts** to **7,562 exact-unique** and **7,539 normalized-unique** malicious identities. Per-source normalized counts in Table 1 can overlap because the same identity may occur in multiple sources.

Broader scaffold reuse is handled separately from identity and threat semantics. On one representative per normalized malicious identity, a frozen static-similarity pipeline at threshold 0.68 yields **4,588 operational structural families**. We use these families only for reuse audits and malicious-side structural-disjoint splitting; they encode operational structural reuse with no attack, campaign, actor, or threat-class semantics. A blinded positive-only review of 72 sampled within-family pairs provides a bounded coherence check, with the full method and limitations reported in Appendix C.

4.4 BENIGN POOL, LABEL CONFLICTS, AND FINAL BENCHMARK

A detection benchmark also needs credible negatives. We separate **48,217 benign candidates** into Main and Auxiliary pools according to artifact availability and source evidence. Main benign records require an actual Skill artifact plus strong or moderate benign evidence; marketplace-unflagged, scanner-clean, silver, or otherwise weak negatives remain Auxiliary. This yields 2,251 raw Main-benign artifacts (2,238 normalized-unique) and 45,966 raw Auxiliary-benign artifacts (44,327 normalized-unique). Auxiliary examples remain useful for audit and future work but are not used as primary benign ground truth.

Finally, we compare exact and normalized identities across malicious and benign pools. **Thirty-four normalized identities** receive conflicting malicious/benign labels across frozen sources. We exclude every conflicting identity from primary evaluation and retain it for consistency auditing, avoiding new automatic adjudication. The resulting frozen benchmark contains **9,740 normalized-unique Skills: 7,505 malicious and 2,235 Main benign**. Every evaluation protocol starts from this same master table; no split-specific relabeling or synthetic oversampling changes the underlying benchmark population.

5 THREAT LANDSCAPE OF MALICIOUSSKILLBENCH

A comprehensive benchmark should characterize both artifact scale and the malicious behavior covered by its contributing sources. We therefore harmonize source-native threat metadata into a common attack taxonomy without inferring labels from Skill text. Direct labels and deterministic strong-semantic mappings support attack characterization for **4,983 of 7,505 primary malicious identities (66.4%)** across **11 multi-label attack categories**. Nine of the 11 Core-contributing sources provide mappable per-unit attack annotations; unsupported units remain unannotated, with no model-inferred labels added.

5.1 ATTACK COVERAGE IS BROAD BUT SOURCE-DEPENDENT

Figure 2a shows several recurring behaviors. *Execution / Code Delivery* appears in **3,320** identities (66.6% of the mapped subset), followed by *Instruction / Goal / Memory Manipulation* in **1,671** (33.5%) and *Privilege / Tool / Authority Abuse* in **1,013** (20.3%). Credential access, data exfiltration, persistence, supply-chain abuse, resource abuse, integrity manipulation, defense evasion, and discovery provide additional coverage. Because the taxonomy is multi-label, percentages do not sum to 100%.

The aggregate distribution hides strong source concentration (Figure 2b). SkillTrustBench contributes 2,755 of the 3,320 execution-coded identities and 1,258 of the 1,671 instruction-manipulation identities, whereas MalSkillBench contributes 262 of the 330 resource/availability-abuse identities. Other categories draw from different mixtures of wild, synthetic, injected, backdoored, and test-fixture sources. The contributing datasets therefore provide complementary, source-specific threat coverage: different sources can expose substantially different threat profiles.

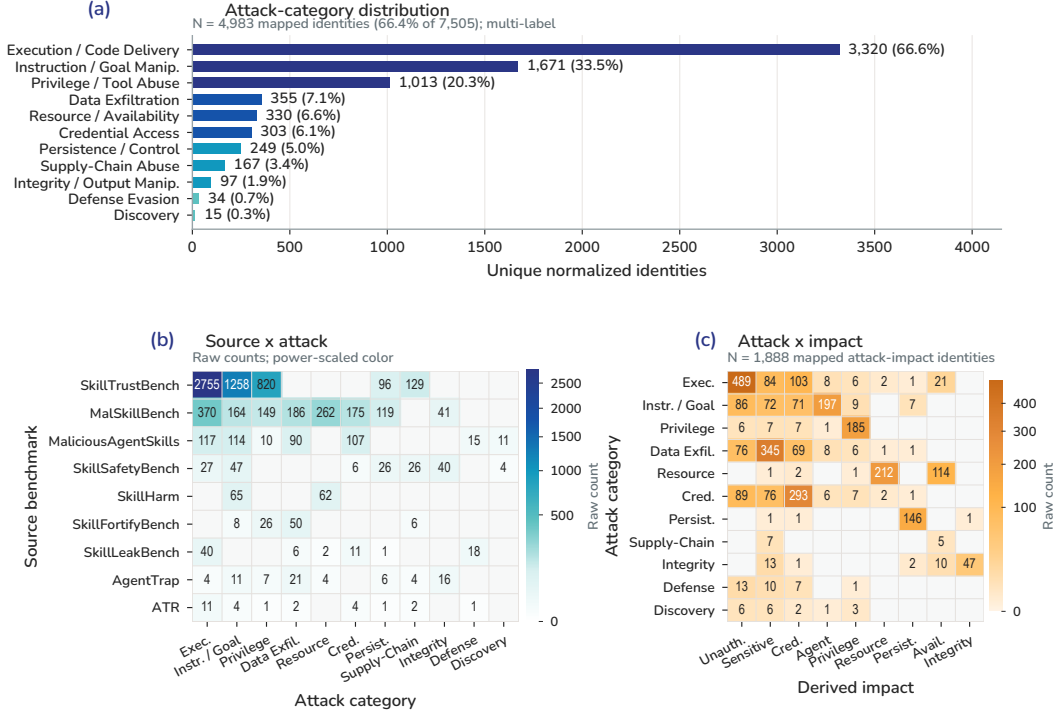


Figure 2: Threat landscape of MALICIOUSSKILLBENCH. **(a)** Prevalence of 11 harmonized attack categories among 4,983 malicious identities with direct or strong-semantic source-native mappings; categories are multi-label and percentages use this mapped subset. **(b)** Source-wise attack composition for the nine Core sources with mappable annotations; cells show raw counts, with power-normalized color intensity for visibility. **(c)** Attack-impact co-occurrence for the 1,888 identities with both mappings. Impact labels are conservative high-level derived mappings available for a bounded subset of the corpus.

5.2 DERIVED IMPACTS PROVIDE A MORE CONSERVATIVE VIEW

Explicit source-native impact labels are sparse, so impact characterization remains separate from the attack taxonomy. Conservative high-level impact mappings are supported for **2,128 of 7,505 malicious identities (28.4%)**, and **1,888 (25.2%)** have both attack and impact mappings. Figure 2c therefore visualizes this bounded mapped subset. Within that subset, execution/code delivery most often co-occurs with unauthorized code execution or system control (489 identities), data exfiltration/disclosure with sensitive-data disclosure (345), and credential access with credential compromise (293). These are descriptive co-occurrences, not causal transitions or benchmark-wide ground truth.

Takeaway. The consolidated benchmark broadens observed threat coverage while revealing how unevenly that coverage is distributed across existing resources. This heterogeneity is itself a benchmark finding: no single source represents the full observed malicious-Skill landscape, which motivates both multi-source construction and source-aware evaluation.

6 BENCHMARKING MALICIOUS AGENT SKILL DETECTION

6.1 EVALUATION DESIGN

All evaluations use the frozen 9,740-unit master table (7,505 malicious / 2,235 benign). **Random** is label-stratified 70/10/20; **Malicious-Structural-Disjoint** keeps each of the 4,588 malicious structural families atomic across partitions; and **Source-Disjoint** holds out SRC009, SRC011, and SRC012 after removing eight identities whose provenance crosses held-out and non-held-out sources. Source-

Balanced Random is a composition diagnostic; exact split inventories and leakage audits are in Appendix F.

Learned baselines use only inert primary Skill instruction text: word TF-IDF with logistic regression or linear SVM, and character `char_wb` TF-IDF with linear SVM. We report Macro-F1, malicious recall, and benign FPR_B . The same primary-artifact representation is scanned by three public tools with pre-registered gates: **Cisco-local-behavioral** (local HIGH/CRITICAL gate), **SkillFortify-offline** (MEDIUM+), and **SkillSpector-static** (LLM disabled; native block gate). Technical failures remain abstentions; all three have 100% coverage on Source-Disjoint. Because learned models are protocol-trained and scanners use fixed external configurations, this is an operational comparison that does not isolate model capacity (Appendix J).

6.2 FINDING 1: RANDOM EVALUATION OVERSTATES ROBUSTNESS

Table 2 reports the learned baselines. Random Macro-F1 is 0.882–0.932. Enforcing malicious structural-family disjointness reduces Random by only 0.016–0.038, whereas Source-Disjoint falls to 0.653–0.665. The strongest word TF-IDF SVM scores **0.932/0.916/0.665** on Random/Malicious-Structural-Disjoint/Source-Disjoint. Thus controlling broader reuse changes performance modestly relative to the gap created by holding out entire sources.

Table 2: Primary detector results. Values are three-seed mean Macro-F1. SB is Source-Balanced Random; FPR_B is the benign false-positive rate (malicious is the positive class).

Model	Random	SB	M-Struct.	Source	Rand. FPR_B	Src. FPR_B
Word TF-IDF + LR	.882	.874	.860	.661	.105	.620
Word TF-IDF + SVM	.932	.921	.916	.665	.094	.624
Char TF-IDF + SVM	.921	.907	.883	.653	.098	.644

6.3 FINDING 2: THE MAIN CROSS-SOURCE FAILURE IS BENIGN OVER-FLAGGING

On Source-Disjoint, learned-detector malicious recall remains 94.4–95.7%, but benign FPR reaches 62.0–64.4%. The word-SVM flags **340/545 benign Skills** while missing only **37/839 malicious Skills**; SRC011 contributes 293 false positives. A format-only model is much weaker (Random Macro-F1 0.486). Balancing lowers word-SVM Source-Disjoint benign FPR from 62.4% to 43.3% and raises Macro-F1 from 0.665 to 0.710, but neither balancing nor scaffold sanitization removes the source-conditioned gap (Appendices I and H). The learned models therefore fail primarily by treating unfamiliar benign source conventions as malicious, not by losing malicious recall.

6.4 FINDING 3: EXISTING SCANNERS DO NOT RESOLVE THE TRADE-OFF

Table 3 compares the word-SVM with three fixed scanner configurations on the same Source-Disjoint test. Cisco and SkillSpector keep benign FPR at **1.1%** and **0.55%**, but detect only **2.5%** and **0%** of malicious Skills. SkillFortify raises malicious recall to **25.3%** while benign FPR reaches **49.9%**; the word-SVM reaches 95.6% recall at 62.4% FPR.

Table 3: Source-Disjoint operational comparison. Scanner coverage is 100%; scanners use fixed external settings, while word-SVM is protocol-trained.

Detector	Setting	Mal. recall	Benign FPR	Macro-F1
Word TF-IDF + SVM	learned	.956	.624	.665
Cisco-local-behavioral	fixed scanner	.025	.011	.308
SkillFortify-offline	fixed scanner	.253	.499	.349
SkillSpector-static	fixed scanner	.000	.006	.281

On SRC011’s 455 benign Skills, the word-SVM produces 293 false positives, SkillFortify 272, Cisco 6, and SkillSpector 3. SkillFortify also benefits from the related SRC012/SkillFortifyBench source: excluding SRC012 lowers its Source-Disjoint Macro-F1 from 0.349 to 0.254 and worsens both recall

and FPR. This is a source-overlap sensitivity, not evidence of memorization. Across the evaluated methods, lower false-positive rates are therefore obtained only by moving to much lower malicious recall; no detector occupies the desired high-recall, low-FPR regime on held-out sources.

7 DISCUSSION

Detection quality is inherently two-sided. Source-Disjoint measures source-conditioned stress under coupled provenance, construction, labeling, and class composition. Learned detectors preserve 94.4–95.7% malicious recall while benign FPR reaches 62.0–64.4%; Cisco and SkillSpector reduce benign FPR to 1.1% and 0.55% but detect only 2.5% and 0% of held-out malicious Skills, and SkillFortify lies between these regimes. Random-split Macro-F1, attack recall, or false alarms alone therefore provide incomplete views of detector utility. A realistic benchmark must report malicious detection and benign over-flagging together.

Comprehensiveness requires diversity and control. Figure 2 shows that contributing datasets cover different attack profiles, while Section 6.3 shows that benign diversity is equally consequential. Simply adding more malicious rows is insufficient if those rows duplicate existing content, concentrate in a few construction styles, or are paired with narrow benign data. Identity, structural reuse, attack semantics, and source provenance should remain separate benchmark concepts: identity/conflict control precedes splitting; source/evidence metadata support audit and stratification and are excluded from detector features.

8 LIMITATIONS AND THREATS TO VALIDITY

Coverage and characterization. *Comprehensive* refers to broad, traceable artifact-level consolidation of 13 frozen public sources; coverage is bounded by those sources. Source-Disjoint measures source-conditioned generalization with provenance, construction, labeling, and class composition coupled. SRC002/SRC004 use author-provided historical artifact snapshots, with four unresolved SRC004 cases excluded. Attack mappings cover 4,983/7,505 malicious identities, derived impacts 2,128, and their intersection 1,888; structural families are operational reuse groupings for audit and split control.

Benign and detector scope. The Main benign pool favors label confidence over ecological balance, so its source coverage remains narrower than the malicious side. Learned baselines and the common scanner track use static primary Skill artifacts and exclude package-level/runtime behavior. SkillSpector is evaluated in static `--no-llm` mode; SkillFortify’s SRC012 overlap benefits its held-out aggregate; and Cisco uses a documented local compatibility environment with a dependency-version deviation. These conditions bound claims to the evaluated benchmark and configurations.

9 CONCLUSION

We introduced MALICIOUSSKILLBENCH, a comprehensive benchmark that consolidates 13 public sources into 9,740 conflict-clean normalized-unique Skills with explicit identity, reuse, evidence, and threat-coverage accounting. Its 11-category threat characterization shows that existing datasets cover complementary, source-specific attack profiles. Evaluation then reveals a persistent detection trade-off: learned models retain high malicious recall by over-flagging unfamiliar benign Skills, while fixed off-the-shelf scanners reduce false alarms only by moving to much lower recall. Reliable malicious Agent Skill detection therefore remains open, and progress requires diverse malicious and benign coverage together with source-aware, two-sided evaluation.

REPRODUCIBILITY STATEMENT

We freeze source revisions, the canonical metadata manifest, Core eligibility rules, exact and normalized hashes, structural-family assignments, benchmark master tables, split manifests, leakage checks, threat-characterization mappings, text-preprocessing rules, scanner verdict contracts, and detector configurations. The public [project page](#), [GitHub repository](#), and [Hugging Face dataset](#) document the

benchmark release, frozen evaluation protocols, and released artifacts underlying the reported results without requiring execution of untrusted Skill payloads. All 9,740 benchmark identities are publicly represented. Exact frozen static Skill text is available for 9,735 identities (7,500 malicious and 2,235 benign); for five malicious records containing sensitive credential material, the exact original text is withheld and a sanitized representation is provided instead. These five sanitized representations are not bit-for-bit identical to the frozen inputs used in the reported experiments.

ETHICS STATEMENT

This work studies malicious Agent Skills and therefore involves dual-use security artifacts. We treat all Skill contents as untrusted static data and do not execute malicious payloads, helper scripts, or embedded commands during benchmark construction or the reported detector experiments. Full-package redistribution remains subject to source-specific licenses and constraints. For five malicious records containing sensitive credential material, the exact frozen text is withheld and a sanitized public representation is released instead. The benchmark is intended to support defensive detection and auditing, and released documentation should avoid operationalizing harmful payloads beyond what is necessary for reproducible security research. The detailed release, redistribution, safety, intended-use, and maintenance contract is documented in Appendix L.

AI USE STATEMENT

Generative AI tools were used to assist literature search, workflow scripting, prose drafting and editing, LaTeX organization, consistency checking, and the explicitly reported blind structural-template review. The blind review is identified in the paper as LLM-based and is not treated as human ground truth. The authors remain responsible for the scientific content and reviewed the reported claims, citations, benchmark statistics, experimental results, and final manuscript text.

REFERENCES

- Wenbo Guo, Wei Zeng, Chengwei Liu, Xiaojun Jia, Yijia Xu, Lei Tang, Yong Fang, and Yang Liu. MalSkillBench: A Runtime-Verified Benchmark of Malicious Agent Skills. *arXiv preprint arXiv:2606.07131*, 2026.
- Haomin Zhuang, Hanwen Xing, Yujun Zhou, Yuchen Ma, Yue Huang, Yili Shen, Yufei Han, and Xiangliang Zhang. AgentTrap: Measuring Runtime Trust Failures in Third-Party Agent Skills. *arXiv preprint arXiv:2605.13940*, 2026.
- Yi Liu, Zhihao Chen, Yanjun Zhang, Gelei Deng, Yuekang Li, Jianting Ning, and Leo Yu Zhang. Malicious Agent Skills in the Wild: A Large-Scale Security Empirical Study. *arXiv preprint arXiv:2602.06547*, 2026.
- Yi Liu, Weizhe Wang, Ruitao Feng, Yao Zhang, Guangquan Xu, Gelei Deng, Yuekang Li, and Leo Zhang. Agent Skills in the Wild: An Empirical Study of Security Vulnerabilities at Scale. *arXiv preprint arXiv:2601.10338*, 2026.
- Zhihao Chen, Ying Zhang, Yi Liu, Gelei Deng, Yuekang Li, Yanjun Zhang, Jianting Ning, Leo Yu Zhang, Lei Ma, and Zhiqiang Li. How Your Credentials Are Leaked by LLM Agent Skills: An Empirical Study. *arXiv preprint arXiv:2604.03070*, 2026.
- Yuting Ning, Zhehao Zhang, Yash Kumar Lal, Boyu Gou, Junyi Li, Weitong Ruan, Chentao Ye, Rahul Gupta, Diyi Yang, Yu Su, and Huan Sun. SkillHarm: Lifecycle-Aware Skill-Based Attacks via Automated Construction. *arXiv preprint arXiv:2606.02540*, 2026.
- Chang Jin, An Wang, Zeming Wei, Kai Wang, Biaojie Zeng, Qiaosheng Zhang, Chao Yang, Jingjing Qu, Xia Hu, and Xingcheng Xu. SkillSafetyBench: Evaluating Agent Safety under Skill-Facing Attack Surfaces. *arXiv preprint arXiv:2605.12015*, 2026.
- Qiusi Zhan, Zhixiang Liang, Zifan Ying, and Daniel Kang. InjecAgent: Benchmarking Indirect Prompt Injections in Tool-Integrated Large Language Model Agents. *arXiv preprint arXiv:2403.02691*, 2024.

-
- Edoardo DeBenedetti, Jie Zhang, Mislav Balunovic, Luca Beurer-Kellner, Marc Fischer, and Florian Tramèr. AgentDojo: A Dynamic Environment to Evaluate Prompt Injection Attacks and Defenses for LLM Agents. *arXiv preprint arXiv:2406.13352*, 2024.
- Hanrong Zhang, Jingyuan Huang, Kai Mei, Yifei Yao, Zhenting Wang, Chenlu Zhan, Hongwei Wang, and Yongfeng Zhang. Agent Security Bench (ASB): Formalizing and Benchmarking Attacks and Defenses in LLM-based Agents. *arXiv preprint arXiv:2410.02644*, 2024.
- Zhiqiang Wang, Yichao Gao, Yanting Wang, Suyuan Liu, Haifeng Sun, Haoran Cheng, Guanquan Shi, Haohua Du, and Xiangyang Li. MCPTox: A Benchmark for Tool Poisoning Attack on Real-World MCP Servers. *arXiv preprint arXiv:2508.14925*, 2025.
- David Schmotz, Luca Beurer-Kellner, Sahar Abdelnabi, and Maksym Andriushchenko. Skill-Inject: Measuring Agent Vulnerability to Skill File Attacks. *arXiv preprint arXiv:2602.20156*, 2026.
- Yunhao Feng, Yifan Ding, Yingshui Tan, Boren Zheng, Yanming Guo, Xiaolong Li, Kun Zhai, Yishan Li, and Wenke Huang. SkillTrojan: Backdoor Attacks on Skill-Based Agent Systems. *arXiv preprint arXiv:2604.06811*, 2026.
- Vincent Koc, Patrick Erichsen, Jacob Tomlinson, Agustin Rivera, Michael Appel, and Nir Paz. ClawHub Security Signals: When VirusTotal, Static Analysis, and SkillSpector Disagree. *arXiv preprint arXiv:2606.01494*, 2026.
- Tencent Zhuque Lab and The Chinese University of Hong Kong (Shenzhen). SkillTrustBench, version 1.0. Benchmark dataset for agent skill security evaluation, 2026.
- Varun Pratap Bhardwaj. Formal Analysis and Supply Chain Security for Agentic AI Skills. *arXiv preprint arXiv:2603.00195*, 2026.
- Wenjie Xiao, Xuehai Tang, Biyu Zhou, Songlin Hu, and Jizhong Han. RouteGuard: Internal-Signal Detection of Skill Poisoning in LLM Agents. *arXiv preprint arXiv:2604.22888*, 2026.
- Bacem Etteib, Daniele Lunghi, and Tegawende F. Bissyande. Detecting Malicious Agent Skills in the Wild using Attention. *arXiv preprint arXiv:2606.23416*, 2026.
- Rui Yang, Michael Fu, Kla Tantithamthavorn, Chetan Arora, and Joey Chua. SkillGate: Cost Efficient Runtime Malicious Skill File Detection in Coding Agents. *arXiv preprint arXiv:2607.25619*, 2026.
- Tu Lan and Chaowei Xiao. Runtime Skill Audit: Targeted Runtime Probing for Agent Skill Security. *arXiv preprint arXiv:2606.11671*, 2026.
- Zimo Ji, Congying Xu, Zongjie Li, Yudong Gao, Xin Wei, Shuai Wang, and Shing-Chi Cheung. Cloak and Detonate: Scanner Evasion and Dynamic Detection of Agent Skill Malware. *arXiv preprint arXiv:2607.02357*, 2026.
- Su Wang, Pin Qian, Yihang Chen, Junxian You, Xiaoyuan Wang, Xiaochong Jiang, Lifei Liu, Haoran Yu, and Jingzhou Xu. When Safe Skills Collide: Measuring Compositional Risk in Agent Skill Ecosystems. *arXiv preprint arXiv:2606.00448*, 2026.
- XiaoJun Jia, Jie Liao, Simeng Qin, Ke Ma, Wenbo Guo, Yebo Feng, Aishan Liu, and Yang Liu. Seeing Is Not Screening: Multimodal Hidden Instruction Attacks on Agent Skill Scanners. *arXiv preprint arXiv:2606.18198*, 2026.
- Puyu Zeng, Simeng Qin, Jingzhi Li, Ju Jia, Zheli Liu, and XiaoJun Jia. ColluSkill: Adversarial Cross-Skill Composition for Evading Agent Skill Scanners. *arXiv preprint arXiv:2608.09732*, 2026.
- Suchin Gururangan, Swabha Swayamdipta, Omer Levy, Roy Schwartz, Samuel R. Bowman, and Noah A. Smith. Annotation Artifacts in Natural Language Inference Data. *arXiv preprint arXiv:1803.02324*, 2018.
- Pang Wei Koh, Shiori Sagawa, Henrik Marklund, Sang Michael Xie, Marvin Zhang, et al. WILDS: A Benchmark of in-the-Wild Distribution Shifts. *arXiv preprint arXiv:2012.07421*, 2021.
- Ishaan Gulrajani and David Lopez-Paz. In Search of Lost Domain Generalization. *arXiv preprint arXiv:2007.01434*, 2021.

A SOURCE REGISTRY AND BENCHMARK SCOPE

A.1 SCOPE AND ACQUISITION PRINCIPLES

MALICIOUSSKILLBENCH is built from a frozen public-source registry with pinned source revisions. We include public datasets and security corpora that materially characterize the Agent Skill attack surface, even when their released unit or supervision is not eligible for the Core malicious pool. This distinction is deliberate: the registry is broader than the primary detection benchmark. A source can therefore contribute Core malicious artifacts, high-confidence Main-benign artifacts, Auxiliary evidence, or a mixture of these roles.

The public source-of-record revisions are frozen and traceable. We preserve *reported* and *acquired* counts separately and do not synthesize missing records to force agreement with a paper or README. Acquisition is static only: archives and text are inspected for canonicalization and hashing, but Skill code, helper programs, payloads, URLs, installers, evaluators, and test harnesses are never executed. For SRC002 and SRC004, the public revisions remain the source of record while eligible malicious rows are linked to author-provided historical research snapshots that recover the corresponding static Skill artifacts. Table 4 gives the complete 13-source snapshot used by this paper.

Table 4: Complete frozen source registry used by this paper. “Reported” is the source/paper count at the recorded public revision; “Acquired” is the number of source records materialized into the canonical registry. Core M is the number of malicious Skill artifacts admitted to Core, including SRC002/SRC004 artifacts recovered from author-provided historical research snapshots. Main B is the raw high-confidence benign contribution before cross-label conflict exclusion. A dash denotes zero.

ID	Source	Reported	Acquired	Core M	Main B	Canonical benchmark role
SRC001	MalSkillBench	7,944	7,944	3,944	–	Core malicious; source benign labels retained outside Main
SRC002	MaliciousAgentSkills Bench	98,380	98,380	157	–	Recovered malicious artifacts enter Core; public metadata/security labels otherwise remain Auxiliary
SRC003	Skill-Inject	202	319	–	–	Auxiliary only: released unit is an injection-task pair
SRC004	SkillLeakBench	520	520	79	–	Recovered malicious artifacts enter Core; vulnerability-only and unresolved rows remain Auxiliary
SRC005	Agent Skill Malware	350	347	124	–	Core malicious; weak benign labels retained outside Main
SRC006	AgentTrap	141	141	91	50	Core malicious + Main benign
SRC007	ClawHub Security Signals	67,453	67,453	–	–	Auxiliary only: automated silver scanner labels
SRC008	SkillTrojan	3,000+	3	1	2	Core example + Main benign examples; full reported corpus unavailable
SRC009	SkillHarm	879	879	879	–	Core malicious
SRC010	SkillTrustBench	5,520	5,520	2,863	1,643	Core malicious + Main benign; vulnerable rows remain Auxiliary
SRC011	ATR Skill Security Benchmark	498	498	32	466	Core malicious + Main benign
SRC012	SkillFortifyBench	540	540	90	90	Claude Skill artifacts enter Core/Main; MCP/OpenClaw formats remain Auxiliary
SRC013	SkillSafetyBench	155	155	154	–	Skill-carried attack cases enter Core; one environment-only case is Auxiliary

A.2 CORE, MAIN-BENIGN, AND AUXILIARY ROLES

The Core malicious pool is intentionally narrower than the source registry. A record enters Core only when the released or recovered research unit is a Skill artifact (`skill.md` or `skill.package`), canonical intent is malicious, static content is available for content hashing/detector input, and the record is traceable to the frozen source revision. **Eleven sources** satisfy these requirements for at least one malicious artifact. Five sources—SRC006, SRC008, SRC010, SRC011, and SRC012—also contribute strong/moderate Main-benign artifacts before conflict exclusion, yielding 2,251 raw Main-benign records (2,238 exact- and normalized-unique units).

The remaining source content is not discarded. Vulnerability-only records, task-pair attack cases, metadata-only verdicts without recovered artifacts, automated scanner labels, non-Skill formats, weak/silver benign labels, and environment-only cases are retained as Auxiliary data with their original source semantics. Table 5 explains the two registry sources that contribute no Core malicious artifact. Mixed-role sources are handled at record level: SRC002 and SRC004 now contribute recovered malicious Skill artifacts to Core while their public metadata-only/non-malicious rows

retain Auxiliary semantics; SkillFortifyBench contributes only Claude Skill artifacts to Core/Main while MCP/OpenClaw formats remain Auxiliary; and SkillSafetyBench contributes 154 Skill-carried attack cases while its single environment-only case remains Auxiliary.

Table 5: Why the two registry sources with zero Core malicious artifacts remain Auxiliary. Auxiliary status is a semantic decision about the released unit/evidence, not a judgment that the source is unimportant.

ID	Released object / supervision	Reason for Auxiliary-only status
SRC003	injection-task pairs over host Skills	The benchmark unit is a task pair with no malicious Skill artifact; contextual cases are additionally retained as harmful/dual-use under their source semantics.
SRC007	sanitized marketplace content with automated security signals	Labels are automated silver supervision (clean/suspicious/malicious signals), so scanner-positive records are not promoted to malicious Core ground truth.

A.3 FROZEN REVISIONS AND RELEASE CONSTRAINTS

Reproducibility requires distinguishing the source snapshot used for analysis from source/package redistribution beyond the public benchmark text layer. Table 6 records the frozen revision, acquisition status, upstream license, and source/package redistribution policy. “Allowed” refers only to the acquired public artifact under the recorded license; it does not override upstream terms. For SRC002 and SRC004, the recovered malicious artifacts come from author-provided historical research snapshots; the exact frozen static Skill text for accepted public identities is now released while that historical provenance remains recorded. Where full package/archive redistribution is restricted or unclear, the benchmark exposes the per-identity text representation together with source adapters, revision identifiers, metadata, and hashes, while omitting the underlying package bytes.

Table 6: Frozen source revisions, licensing, and source/package redistribution policy. Revisions are abbreviated here for readability; the release registry stores full commit/revision identifiers and checksums. The policy column concerns upstream package/archive material beyond the public per-identity static-text layer described in Appendix L. “Partial” means the pinned public artifact does not exactly reproduce the count or artifact set claimed by the associated paper/README; no missing records are reconstructed.

ID	Revision	Status	Upstream license	Source/package redistribution policy
SRC001	06e08312	completed	academic-research-only	adapter only
SRC002	422bf340	completed	MIT	exact frozen static Skill text released; historical snapshot provenance retained
SRC003	182f3d9d	partial	MIT	allowed
SRC004	8264436a	completed	MIT	exact frozen static Skill text released; historical snapshot provenance retained
SRC005	5cff435d	partial	MIT	allowed
SRC006	ab13f59d	completed	terms not provided	metadata/hash only
SRC007	69dcdbd32	completed	MIT	allowed
SRC008	2864c752	partial	Apache-2.0 snapshot	allowed for acquired repository snapshot
SRC009	cc21f909	completed	CC-BY-4.0	metadata/hash only
SRC010	f90517b7	completed	CC-BY-NC-SA-4.0	metadata/hash only
SRC011	7219b10d	completed	MIT	allowed
SRC012	eb9d5a9c	completed	MIT	allowed
SRC013	e0589d7b	completed	Apache-2.0	allowed

A.4 DOCUMENTED SOURCE DISCREPANCIES AND RECOVERY CASES

We preserve version/count discrepancies and recovery boundaries as explicit provenance. The most consequential cases are:

- **SRC002 (MaliciousAgentSkillsBench).** The public snapshot contains 98,380 metadata rows, including 157 confirmed-malicious rows, but does not release the corresponding raw malicious Skill packages. We link all 157 rows to author-provided historical research artifacts with high-confidence mapping and admit those static artifacts to Core. The public metadata remains the source of record for provenance; exact frozen static Skill text for the accepted benchmark identities

is included in the public benchmark release, without treating the historical package snapshot as the public source of record.

- **SRC003 (Skill-Inject).** The paper reports 202 injection–task pairs over 23 Skills, whereas the pinned current commit contains 319 pairs over 33 referenced host Skill paths. We retain the pinned 319-row snapshot, mark the acquisition as partial relative to the paper, and keep the task-pair unit outside Core.
- **SRC004 (SkillLeakBench).** The corresponding empirical study reports 520 affected Skills ([Chen et al., 2026](#)); the public snapshot contains 437 vulnerable and 83 malicious metadata rows but does not contain the raw malicious `SKILL.md` artifacts. Author-provided historical packages resolve 79 malicious artifacts under the Core rule, and exact frozen static Skill text for accepted benchmark identities is included in the public benchmark release. Four ambiguous multi-Skill cases remain outside Core, and the 437 vulnerability-only rows remain Auxiliary.
- **SRC005 (Agent Skill Malware).** The README reports 350 rows (127 malicious + 223 benign), but the fixed revision contains 347 (124 malicious + 223 benign). The three missing malicious records are not reconstructed; Core therefore contains the 124 acquired malicious artifacts.
- **SRC006 (AgentTrap).** A previous metadata-only ingestion did not contain runnable Skill packages. The frozen P1 revision safely recovered all 141 public packages (91 malicious + 50 benign) for local static research. Because the upstream archive provides no explicit redistribution terms, full package/archive redistribution remains restricted; the public benchmark still provides its per-identity static-text representation and reproducibility metadata.
- **SRC008 (SkillTrojan).** The paper reports a curated SkillTrojanX corpus with 3,000+ backdoored Skills, but the pinned official repository exposes only three example Skill packages. We acquire exactly those three examples (one malicious, two benign) and do not generate the missing paper-scale corpus.
- **SRC013 (SkillSafetyBench).** The benchmark reports 155 adversarial cases. Static carrier auditing finds 154 cases with an explicitly injected/modified file inside a Skill package and one environment-only case; the former enter Core and the latter remains Auxiliary.

These cases illustrate why `MALICIOUSSKILLBENCH` treats source revision, released artifact unit, recovered-artifact provenance, and acquired count as first-class benchmark metadata. “Paper-reported size” and “artifact-level samples available for a frozen evaluation snapshot” are treated as distinct quantities.

B CANONICAL TAXONOMY AND DATA MODEL

The unified registry is intentionally multi-axis: *what a record is labeled as, where it came from, how strongly that label is supported, what evidence supports it, and whether it is an original or derived artifact* are represented separately. This design prevents a source-specific word such as “malicious,” “suspicious,” or “clean” from silently determining benchmark role. The schema is frozen for this paper; source labels are retained losslessly alongside canonical fields.

B.1 CANONICAL RECORD SCHEMA

Table 7 summarizes the field families used by the frozen benchmark. Stable identifiers and source metadata preserve traceability; semantic fields separate intent, provenance, confidence, and evidence; content hashes support conservative identity checks; lineage fields are populated only from source-published relationships; and release fields document what may be redistributed. Fields used only for auditing or split construction are never supplied to the text detectors in Section 6.

Table 7: Field groups in the frozen canonical schema. Fields shown are representative; source-native labels are retained in addition to the canonical fields.

Field group	Representative fields	Purpose
Identity	canonical_id, source_id, source_record_id	Stable benchmark identity while retaining upstream traceability.
Source snapshot	source_dataset, repository_commit, dataset_snapshot_date, paper version	Reconstruct the exact public revision used for acquisition.
Artifact / role	artifact_unit, core_malicious_skill, auxiliary_type	Separate Skill artifacts from task pairs, metadata, fixtures, and other non-Core units.
Semantic labels	source_label, intent_label, provenance, ground_truth_strength, evidence_level	Preserve source semantics while exposing orthogonal canonical axes.
Content identity	skill_sha256, normalized_skill_sha256	Exact and conservative formatting-normalized identity; no semantic equivalence claim.
Lineage	lineage_status, lineage_resolution, lineage_basis, base_skill_id, variant_id, base_skill_semantics	Preserve only source-supported parent/family relationships and explain what a base identifier means.
Release / safety	license, redistribution_status, local/static content reference	Record what can be audited or redistributed without executing potentially malicious artifacts.

The canonical manifest contains 182,699 source records. Its observed intent distribution is 142,490 benign, 29,840 uncertain, 8,779 malicious, 1,451 vulnerable, and 139 harmful_or_dual_use. Importantly, canonical intent is not benchmark membership: **8,414** of the 8,779 malicious-intent records satisfy the stricter Core artifact rule in the frozen benchmark, while benign records are further separated into Main and Auxiliary pools according to evidence strength and artifact availability.

B.2 INTENT LABELS

Canonical intent answers *what claim is being made about the record*; it does not encode origin or confidence. Table 8 gives the operational definitions used during source mapping. We choose the most conservative label supported by the source semantics: ambiguous scanner findings remain uncertain, vulnerability findings remain vulnerable, and harmful-but-not-intentionally-malicious cases remain harmful_or_dual_use.

Table 8: Canonical intent labels. Counts are over all 182,699 source records before Core/Main filtering.

Intent	Records	Operational meaning
malicious	8,779	The source supports intentional malicious or unauthorized behavior associated with the record. Core eligibility is checked separately.
vulnerable	1,451	A weakness, exposure, or exploitable condition is reported, without sufficient evidence that the Skill artifact itself is intentionally malicious.
harmful_or_dual_use	139	The case can facilitate harmful behavior, but the released case is not treated as an intentionally malicious Skill artifact.
benign	142,490	The source presents the record as normal/safe/negative; confidence and admissibility as Main benign are represented separately.
uncertain	29,840	Suspicious, ambiguous, or scanner-derived security signal that is insufficient for a stronger canonical intent claim.

B.3 PROVENANCE TAXONOMY

Provenance answers *how the artifact arose*. It is independent of label confidence: a synthetic artifact can have strong ground truth, while a wild record can have only silver scanner evidence. Table 9 reports the controlled vocabulary and the frozen Core-malicious distribution. `mixed_unresolved` is used when a source reports an aggregate mixture (for example, wild and generated records) but does not publish a trustworthy row-level mapping. We do not infer such provenance from filenames, content similarity, or repository context.

Table 9: Provenance vocabulary and frozen Core-malicious distribution. Raw counts are source records and sum to 8,414. Normalized-unique counts are identity coverage by provenance and can overlap when the same normalized identity appears in sources with different provenance labels.

Provenance	Core raw	Norm. unique	Meaning
wild	413	364	Collected from a real upstream ecosystem/repository under the source’s published semantics; no benchmark-authored attack construction.
synthetic	295	295	Synthetic standalone Skill/test artifact generated or authored for evaluation.
injected	3,460	3,352	Malicious/harmful content is inserted into a pre-existing carrier, host Skill, or task construction.
backdoored	193	161	Benign-looking Skill contains hidden or triggered malicious behavior.
test_fixture	109	107	Curated or benchmark-authored fixture used as a controlled security test artifact.
mixed_unresolved	3,944	3,430	Source reports a mixture of origins but lacks a trustworthy row-level provenance mapping.
unknown	0	0	No supported provenance classification is available.

B.4 LABEL STRENGTH AND EVIDENCE ARE ORTHOGONAL

We represent confidence and evidentiary mechanism as two separate axes. *Ground-truth strength* describes how strongly the benchmark is willing to rely on a label; *evidence level* describes what kind of evidence produced that label. For example, a deliberately constructed attack can be *strong/constructed*, a manually curated benign artifact can be *moderate/static*, and a marketplace record can be *silver/scanner*. Consequently, evidence type must not be interpreted as an ordinal confidence score.

Table 10: Ground-truth strength and evidence-level vocabularies. These axes are intentionally independent. Full-registry counts are shown for observed values.

Ground-truth strength		
strong	10,525	High-confidence source evidence suitable for primary ground truth when artifact/unit constraints are also satisfied.
moderate	2,275	Meaningful source evidence with weaker certainty than strong; may still enter Core/Main under source-specific rules.
silver	169,676	Automated/scanner-derived or weakly supervised labels; retained for analysis but not sufficient alone for Core/Main ground truth.
weak	223	Weak negative/heuristic evidence; Auxiliary only.
unknown	0	No confidence assignment.
Evidence level		
human+runtime	4,621	Human-grounded label together with runtime/behavioral confirmation.
runtime	141	Behavioral execution/runtime evidence without the combined human+runtime designation.
static	2,359	Static artifact inspection or curated source evidence without runtime confirmation.
scanner	169,676	Automated scanner or security-signal output.
constructed	5,902	Label is known from controlled benchmark construction, injection, or backdoor generation.
human, llm, unknown	0	Controlled vocabulary values reserved for explicit human-only, LLM-only, or unavailable evidence; not observed in the frozen analysis manifest.

In the frozen registry, the full 182,699-record manifest contains 169,676 silver, 10,525 strong, 2,275 moderate, and 223 weak labels. Scanner evidence dominates the full registry because the largest marketplace-security corpora are silver-standard resources. By contrast, the **8,414 raw Core malicious artifacts** contain only strong (8,237) or moderate (177) labels, supported by constructed (3,966), human+runtime (4,180), static (177), or runtime (91) evidence. Scanner-only evidence therefore never enters Core malicious ground truth.

B.5 ARTIFACT UNITS AND CORE ELIGIBILITY

Artifact unit records *what the released or recovered row actually represents*. This distinction is central to the benchmark: a source may publish a security-relevant task pair, scanner verdict, MCP configuration, or environment fixture without releasing a malicious Agent Skill artifact that can be hashed and evaluated as a Skill. Table 11 reports the observed values in the frozen analysis manifest. Only `skill_package` and `skill_md` are eligible artifact units for the Core malicious pool, and even those must also satisfy intent, traceability, content-availability, and source-mapping requirements.

Table 11: Observed artifact units in the frozen analysis manifest. Core counts show the stricter malicious-Skill subset; recovered SRC002/SRC004 malicious artifacts account for the increase in `skill_md` units relative to the earlier snapshot.

Artifact unit	All records	Core malicious	Interpretation / Core policy
<code>skill_package</code>	82,094	7,932	Complete or package-level Skill artifact; Core-eligible when all other rules pass.
<code>skill_md</code>	1,261	482	Primary Skill instruction artifact; Core-eligible when all other rules pass.
<code>task_pair</code>	319	0	Attack/task evaluation pair; no released malicious Skill artifact; Auxiliary.
<code>mcp_config</code>	180	0	MCP-format configuration from a multi-format testbed; outside current Skill Core.
<code>openclaw_manifest</code>	180	0	OpenClaw-format manifest from a multi-format testbed; outside current Skill Core.
<code>environment_fixture</code>	1	0	Attack is carried only in the environment and is absent from the Skill package; Auxiliary.
<code>other</code>	98,664	0	Metadata/scanner/vulnerability or other non-Core record representation.

B.6 EVIDENCE-BASED LINEAGE SEMANTICS

Lineage is recorded only when the source publishes a relationship that can be traced without similarity-based inference. We distinguish three concepts. `lineage_status` describes whether a record is standalone, derived, or a variant; `lineage_resolution` describes whether the source-published linkage is fully resolved, only family-level resolved, or unresolved; and `base_skill_semantics` states what a source’s “base” identifier actually denotes. Table 12 defines these fields.

Table 12: Lineage semantics in the frozen schema. Lineage is source-evidenced and is never inferred from textual similarity or structural clustering.

Field	Values	Meaning
<code>lineage_status</code>	<code>independent</code> , <code>derived</code> , <code>variant</code> , <code>unknown</code>	Logical relationship asserted by the source: standalone identity, explicit derivative, member of a published variant family, or unresolved.
<code>lineage_resolution</code>	<code>resolved_official</code> ; <code>partially_resolved_official</code> ; <code>unresolved</code>	Whether an official parent/upstream/logical identity is fully available, only a family-level identity is available, or no trustworthy row-level link exists.
<code>lineage_basis</code>	<code>official_parent/family_ID</code> , <code>upstream_slug</code> , <code>benchmark_authored_identity</code> , <code>logical_construction_ID</code> , <code>none</code>	What source-published signal justifies the linkage; file-names and similarity are not accepted as lineage evidence.
<code>base_skill_semantics</code>	<code>pre-attack_carrier</code> , <code>upstream_identity</code> , <code>benchmark_family</code> , <code>generation_seed</code> , <code>standalone_identity</code> , <code>unknown</code>	Explains what the source-specific <code>base_skill_id</code> denotes so heterogeneous base IDs are not mistaken for a common attack-family unit.
<code>base_skill_id</code> , <code>variant_id</code>	<code>source-scoped_strings</code> or <code>null</code>	Retain the publisher’s identifier when available; values are namespaced/source-specific and are not globally additive.

Among the 8,414 Core records, lineage status is `variant` for 3,892, `derived` for 177, `independent` for 165, and `unknown` for 4,180. Official lineage is fully resolved for 1,380 Core records and family-level partially resolved for another 35; 6,999 remain unresolved. The 1,415 records with official full/partial linkage expose 448 namespaced base identifiers in the analysis manifest, but these identifiers are deliberately *not* summed as “448 independent attacks.” Depending on the source, a base identifier may denote a pre-attack carrier Skill, an upstream Skill identity, a

benchmark family, a logical generation seed, or a standalone benchmark artifact. Structural-template families are a separate audit construct and are never converted into lineage or campaign identity.

B.7 SOURCE-LABEL PRESERVATION AND CONSERVATIVE MAPPING

The original `source_label` is retained alongside canonical intent, strength, and evidence. Mapping is source-specific and follows each release’s documented semantics; the same surface word can support different canonical claims across sources. Table 13 gives representative mappings that illustrate this policy. A canonical malicious intent still does not imply Core membership unless an inspectable Skill artifact can be mapped to the frozen source record under the Core eligibility rule.

Table 13: Representative source-label mappings. Mapping depends on source semantics, evidence, and artifact availability, not on the literal label string alone.

Source	Source label	Canonical intent	Strength / evidence	Benchmark interpretation
SRC002	safe	benign	silver / scanner	Metadata-level negative signal; retained in Auxiliary and excluded from Main benign.
SRC002	confirmed malicious	malicious	strong / human+runtime	Eligible for Core only after high-confidence linkage to an author-provided historical Skill artifact.
SRC007	malicious	uncertain	silver / scanner	Even a literal “malicious” scanner verdict remains uncertain without stronger ground truth.
SRC003	contextual	harmful_or_dual.use	moderate / constructed	Context-dependent harmful task case; not a Core malicious Skill artifact.
SRC010	suspicious	vulnerable	strong/moderate; constructed/static	Source semantics describe vulnerable/suspicious cases without asserting intentional malicious artifacts.
SRC004	malicious	malicious	strong / human+runtime	79 source-malicious rows map to recovered historical Skill artifacts and enter Core; four ambiguous multi-Skill rows remain outside Core.
SRC001	malware	malicious	strong / human+runtime	Inspectable Skill artifact with supported malicious intent; eligible for Core.
SRC010	normal	benign	moderate/static or strong/constructed	High-confidence benign Skill artifact; eligible for the Main-benign candidate pool.

This multi-axis representation is the basis for the benchmark’s evidence-preserving consolidation. It preserves disagreements and evidentiary differences as auditable metadata instead of forcing all upstream taxonomies into a single binary label before deduplication, conflict checking, and split construction.

C DEDUPLICATION AND STRUCTURAL REUSE

The benchmark separates three increasingly permissive notions of reuse: byte-level identity, conservative normalized-text identity, and static structural-template similarity. These levels serve different purposes and are never collapsed into a single notion of “same attack.” Exact and normalized hashes support content identity checks; structural families are an operational grouping used for audit and split construction. No Skill, helper, payload, URL, or executable content is run during any stage of this analysis.

C.1 EXACT AND NORMALIZED CONTENT IDENTITY

Exact identity is SHA-256 over the acquired Skill content. Normalized identity hashes a deterministic text normalization that is intentionally conservative. The frozen normalization decodes valid UTF-8, removes one leading BOM, converts CRLF/CR to LF, strips trailing spaces/tabs on each line, trims leading/trailing blank lines, collapses runs of three or more blank lines to two, and writes exactly one final LF for non-empty text. It does *not* lowercase text, remove Markdown front matter, code, punctuation, or semantic content, and it does *not* paraphrase or rewrite instructions. Normalized equality therefore captures formatting-equivalent identity; semantic equivalence is outside the scope of this identity rule.

Applying the two identity levels to **8,414 Core malicious records** yields **7,562 exact-unique** and **7,539 normalized-unique** contents. Exact deduplication removes 852 redundant raw records (10.1% of Core), while normalization merges 23 additional global identities. Table 14 shows where within-source duplication occurs. Per-source unique counts do not sum to the global unique totals because the same content can appear in more than one source.

Table 14: Frozen Core malicious deduplication by source. “Raw–Exact” is the within-source reduction from repeated byte-identical artifacts; “Exact–Norm.” is the additional within-source reduction after conservative text normalization. Per-source unique counts do not sum to the global unique totals because cross-source identities are shared.

Source	Raw	Exact unique	Norm. unique	Raw–Exact	Exact–Norm.
SRC001	3,944	3,430	3,430	514	0
SRC002	157	157	157	0	0
SRC004	79	67	67	12	0
SRC005	124	124	124	0	0
SRC006	91	89	89	2	0
SRC008	1	1	1	0	0
SRC009	879	739	739	140	0
SRC010	2,863	2,861	2,861	2	0
SRC011	32	31	29	1	2
SRC012	90	90	90	0	0
SRC013	154	154	154	0	0
Global unique	8,414	7,562	7,539	852	23

At the exact-hash level, 131 duplicate clusters contain 983 raw Core records, with a largest cluster of 54 records; 28 exact clusters contain at least ten records. Duplication remains concentrated in a few sources, while the recovered SRC004 artifacts add 12 within-source exact duplicates. These counts describe repeated released/recovered artifacts, not independent attack lineage.

C.2 CROSS-SOURCE CONTENT REUSE

Content reuse also crosses nominal dataset boundaries. Across the frozen Core pool, **105 exact hashes** and **119 normalized hashes** occur in more than one source. Those shared hashes involve 830 raw Core records at exact identity and 871 raw Core records at normalized identity. Table 15 lists every source pair with non-zero normalized overlap.

Table 15: Non-zero cross-source Core content overlap in the frozen benchmark. Coverage is the fraction of each source’s raw Core records participating in a shared normalized hash with the paired source. Pairwise counts overlap when one identity occurs in three or more sources.

Source A	Source B	Exact hashes	Norm. hashes	Norm. cov. A	Norm. cov. B
SRC001	SRC002	3	3	0.13%	1.91%
SRC001	SRC004	21	21	0.79%	35.44%
SRC001	SRC005	69	90	15.14%	72.58%
SRC001	SRC006	1	1	0.03%	1.10%
SRC001	SRC010	78	78	14.63%	2.72%
SRC001	SRC011	6	8	0.35%	28.13%
SRC004	SRC005	0	3	7.59%	2.42%
SRC004	SRC009	1	1	1.27%	3.53%
SRC004	SRC010	7	7	13.92%	0.24%
SRC004	SRC011	4	5	6.33%	15.63%
SRC005	SRC010	63	68	54.84%	2.38%
SRC005	SRC011	4	4	3.23%	15.63%
SRC010	SRC011	0	1	0.03%	3.13%

The overlap is strongly asymmetric. The 90 normalized hashes shared by SRC001 and SRC005 cover 15.14% of SRC001 raw Core records but 72.58% of SRC005. The recovered sources add further observable overlap: 21 normalized hashes are shared by SRC001 and SRC004, covering 35.44% of SRC004 raw Core records, while three are shared by SRC001 and SRC002. A single normalized identity can occur in more than two sources, so pairwise overlap counts are not additive. We therefore report overlap at the artifact-reuse level and make no inference about source ancestry, common actor identity, or campaign membership.

C.3 STATIC STRUCTURAL-SIMILARITY PIPELINE

Exact/normalized equality does not capture templated variants that preserve a common document scaffold while changing names, endpoints, paths, identifiers, parameters, or local insertions. We therefore maintain a separate static structural-similarity partition over one representative per normalized hash. Cluster membership is determined entirely by fixed text features and the pre-specified medium threshold 0.68; no LLM or embedding model decides membership.

Template normalization conservatively replaces front-matter Skill names, URLs, domains, email/IP values, UUIDs and long IDs, filesystem paths, obvious secret values, long numeric payload parameters, environment variables, and assignment-left-hand-side identifiers. Behavior-bearing terms—including credential access, file reads, network sends, shell/subprocess operations, `eval`, encryption, download, and execution—are retained. Template similarity is the weighted score

$$0.36J_{3\text{-gram}} + 0.28C_{\text{tfidf}} + 0.14J_{\text{struct}} + 0.12J_{\text{behavior}} + 0.10\text{containment},$$

where the terms denote token-3-gram Jaccard, TF-IDF cosine, structural-line Jaccard, behavior-token Jaccard, and token containment, respectively.

The frozen partition applies the same operational threshold to **7,539 normalized Core identities**. Relative to the inherited 7,340-node partition, 199 newly recovered normalized identities are integrated with explicit hash-origin bookkeeping: 25 join inherited families, two form one new recovered-only two-node family, and 172 become new singletons. A full family crosswalk confirms that none of the 4,415 inherited families is split or merged. Table 16 reports the resulting partition evolution. The 0.68 threshold is used solely as an operational structural-reuse control. It was fixed independently of detector performance and carries no semantic attack interpretation.

Table 16: Structural-partition evolution at the frozen medium threshold 0.68. The final partition preserves every inherited pre-recovery family without split/merge and integrates 199 newly recovered normalized identities under the same operational similarity rule.

Snapshot	Nodes	Families	Singletons	Non-singleton	Largest	Cross-source
Pre-recovery inherited base	7,340	4,415	3,059	1,356	146	91
Final frozen partition	7,539	4,588	3,219	1,369	146	113

C.4 FAMILY DISTRIBUTION AND CROSS-SOURCE STRUCTURAL REUSE

At threshold 0.68, the frozen partition contains **4,588 operational structural-family identifiers**: 3,219 singletons and 1,369 non-singletons containing 4,320 normalized identities. These identifiers are frozen before final cross-label exclusion: **4,575** are represented by at least one final primary malicious identity, while 13 retained identifiers have no final primary member after conservative cross-label exclusion. Among non-singleton families, median size is 2 and mean size is 3.16; the largest family contains 146 normalized identities spanning SRC001, SRC009, and SRC013. **113 families** contain artifacts associated with more than one source. Table 17 reports the largest pairwise structural overlaps.

Table 17: Largest pairwise cross-source structural overlaps in the frozen partition at threshold 0.68. Coverage is computed over normalized-unique Core units associated with each source. These entries report operational template overlap only, with no lineage or campaign attribution.

Source A	Source B	Shared families	Coverage A	Coverage B
SRC001	SRC010	39	3.38%	3.04%
SRC001	SRC005	36	3.09%	75.81%
SRC001	SRC004	30	2.22%	49.25%
SRC005	SRC010	29	68.55%	2.48%
SRC009	SRC013	26	42.35%	62.99%
SRC004	SRC010	17	26.87%	1.47%
SRC004	SRC005	13	19.40%	40.32%
SRC001	SRC006	11	1.14%	22.47%
SRC001	SRC002	10	0.61%	8.28%
SRC001	SRC011	9	0.35%	34.48%

Structural overlap can be substantial even when exact/normalized hashes do not overlap. SRC009 and SRC013, for example, share no exact or normalized Core hash, yet 26 operational structural families span both sources; those families cover 42.35% of SRC009 normalized units and 62.99% of SRC013. The recovered SRC004 artifacts also expose substantial structural reuse with existing corpora: 30 families span SRC001/SRC004, covering 49.25% of SRC004 normalized identities. This provides scaffold-level reuse evidence under the fixed static method; it does not support claims about copying, shared actors, shared campaigns, or independent attack identity.

C.5 CONNECTED-COMPONENT BRIDGE AUDIT

Connected components can link members indirectly through intermediate nodes even when a member is below threshold relative to a selected representative. The frozen summary flags **15 of 4,588 families** (0.33%) for possible chaining; the largest 146-unit family is among them. We retain the connected-component family IDs as the operational partition and report the bridge flag explicitly; each family remains a connected component and need not form a clique. The recovery crosswalk additionally confirms that artifact recovery did not merge or split any inherited family.

C.6 BLIND STRUCTURAL POSITIVE VALIDATION

Before the artifact-recovery extension, we performed a separate blind positive check on the inherited structural partition using an independent LLM reviewer on anonymized static artifact pairs. The reviewer received neither cluster IDs, similarity scores, threshold values, sampling categories, algorithm predictions, nor earlier reviewer labels. All 72 cases were valid blind cases; there were no blindness violations or unreadable pairs. The reviewer labeled all 72 pairs as sharing the same structural template, all at high confidence. No embedded instruction, script, helper, URL, or payload was executed or followed.

Table 18: Blind structural positive-validation summary. The reviewer saw anonymized static artifact pairs only; cluster identifiers, similarity values, thresholds, sample categories, algorithm predictions, and prior labels were hidden.

Measure	Count
Total / valid blind cases	72 / 72
Blindness violations	0
Same structural template	72
Different structural template	0
Uncertain	0
High-confidence judgments	72
Unreadable / missing	0

Because the final partition preserves every inherited family without split or merge, this validation remains a bounded positive-coherence check for the sampled inherited within-family pairs. Its coverage is limited to those sampled inherited pairs and leaves the 199 recovered identities, newly created families, clustering recall, and threshold semantics unvalidated. The **4,588 families** serve as an operational structural partition for reducing scaffold reuse across evaluation splits; they carry no gold attack-ontology interpretation.

C.7 INTERPRETATION BOUNDARIES

The three reuse levels answer different questions. Exact hashes identify identical acquired content; normalized hashes identify conservatively formatting-equivalent content; structural families identify static scaffold similarity under the frozen feature/threshold pipeline. None of these establishes lineage, actor identity, uploader identity, campaign membership, or attack-mechanism equivalence. Candidate-generation heuristics may miss deep paraphrases that share no selected feature, while static similarity may over-link boilerplate. These limitations motivate the paper’s conservative use of structural family IDs as grouping variables for audit and Malicious-Structural-Disjoint evaluation, with no ground-truth attack-label semantics.

D BENIGN POOL AND CROSS-LABEL CONFLICTS

The negative class is constructed conservatively because “benign,” “clean,” “not flagged,” and “safe” do not carry the same evidentiary meaning across the 13 sources. The primary detection benchmark therefore uses a high-confidence *Main-benign* pool and keeps weaker or non-comparable negative signals in an *Auxiliary-benign* layer. This appendix documents the candidate gates, deduplication accounting, and the cross-label conflict policy that converts 48,217 benign-side candidates into the 2,235 normalized-unique benign units used by the frozen primary benchmark.

D.1 MAIN VERSUS AUXILIARY BENIGN CANDIDATES

A benign-side record is eligible for the Main pool only when it is an inspectable Skill artifact, its source semantics support canonical benign intent, its label strength is strong or moderate, static content is available for hashing and detector input, and the record remains traceable to a frozen source revision. Scanner-clean, marketplace-unflagged, silver, weak, metadata-only, and otherwise non-comparable negative signals remain Auxiliary. Table 19 summarizes this gate.

Table 19: Frozen eligibility gate for the benign reference pools. “Auxiliary” preserves security-relevant negative signals without promoting them to primary benign ground truth.

Criterion	Main-benign requirement	Auxiliary treatment
Released unit	Inspectable Agent Skill artifact usable for static hashing/detector input	Metadata-only, scanner-only, non-Skill, or otherwise non-comparable negative records remain Auxiliary
Canonical intent	<i>benign</i> under source-specific mapping	Uncertain, vulnerable, harmful/dual-use, or unresolved semantics are never collapsed into benign
Label strength	Strong or moderate	Silver, weak, “not flagged,” marketplace-unflagged, and analogous weak negatives remain Auxiliary
Content availability	Static primary Skill content available	Records lacking inspectable Skill text are excluded from the primary negative class
Traceability	Frozen source revision and source record can be reconstructed	Untraceable or revision-ambiguous records are not promoted to Main

Applying the gate yields 2,251 raw Main-benign artifacts and 45,966 raw Auxiliary-benign records. The two pools are kept separate throughout benchmark construction; Auxiliary negatives are not silently promoted merely because they are numerous. Table 20 reports the frozen identity counts.

Table 20: Frozen benign-side pool counts before cross-label conflict exclusion. Main is the primary high-confidence negative pool; Auxiliary retains weaker or non-comparable benign-side evidence.

Pool	Raw	Exact-unique	Normalized-unique	Primary benchmark use
Main benign	2,251	2,238	2,238	Eligible before conflict exclusion
Auxiliary benign	45,966	44,329	44,327	Not used as primary negative ground truth

The Main pool is intentionally much smaller than the full benign-side registry. This trades coverage for label comparability: the primary benchmark asks whether a detector can separate Core malicious Skills from higher-confidence benign Skill artifacts, while the much larger Auxiliary layer remains available for future stress tests, scanner-comparison studies, or separately versioned evaluations.

D.2 MAIN-BENIGN SOURCE CONTRIBUTIONS

Only five frozen sources contribute Main-benign candidates: SRC006, SRC008, SRC010, SRC011, and SRC012. Their raw contributions sum exactly to 2,251 (Table 21). Sources with weaker negative semantics remain outside Main even when they contain records described upstream as benign or clean. For example, SRC001 source-benign records are retained outside Main under the frozen adapter, SRC005 benign rows are weak evidence under the benchmark taxonomy, and scanner-derived negative signals from SRC002/SRC007 remain silver Auxiliary supervision.

Table 21: Sources contributing raw Main-benign candidates before deduplication and conflict exclusion. Counts sum to 2,251.

ID	Source	Raw Main B	Frozen benchmark interpretation
SRC006	AgentTrap	50	Inspectable benign Skill packages with strong/moderate source evidence
SRC008	SkillTrojan	2	Benign example packages in the pinned public repository
SRC010	SkillTrustBench	1,643	High-confidence source-normal Skill artifacts eligible under the canonical benign mapping
SRC011	ATR Skill Security Benchmark	466	Inspectable benign Skill artifacts admitted by the frozen source adapter
SRC012	SkillFortifyBench	90	Benign Claude Skill artifacts; non-Skill MCP/OpenClaw formats remain Auxiliary
Total		2,251	

The resulting source mix is a high-confidence reference set assembled from public sources that expose both an inspectable Skill artifact and sufficiently strong benign-side evidence under the frozen mapping rules. Its coverage is bounded by those source and evidence gates. This restriction is also why source and class composition remain entangled in the Source-Disjoint evaluation.

D.3 BENIGN DEDUPLICATION AND STATIC HANDLING

The benign pools use the same exact and conservative normalized identity definitions as Appendix C. Main-benign deduplication reduces 2,251 raw records to 2,238 exact-unique contents; normalized text identity introduces no additional merge, leaving 2,238 normalized-unique Main candidates before conflict exclusion. The Auxiliary pool reduces from 45,966 raw records to 44,329 exact-unique and 44,327 normalized-unique contents. Thus the primary benign reference set is already close to content-unique before cross-label auditing, whereas the Auxiliary layer contains substantially more repeated content.

Five benign artifacts contain malformed UTF-8. They are processed statically using replacement decoding for text analysis while preserving raw-byte hashes for identity accounting. No affected artifact is executed, and the decoding choice does not alter the frozen raw hash. Benign structural clustering was not part of the frozen malicious-family pipeline; consequently, Malicious-Structural-Disjoint treats each normalized-unique benign unit as a singleton group and performs no post-freeze benign family inference.

D.4 CROSS-LABEL CONFLICT DEFINITION AND ACCOUNTING

After malicious and benign-side canonicalization, we compare exact and normalized content identities across opposite labels. A *cross-label conflict* occurs when the same content identity is represented on the malicious side and on the benign side of the frozen registry. This is a content-level inconsistency signal; it is not itself evidence that either source is wrong.

The frozen audit finds **34 exact-hash conflicts** and **34 normalized-hash conflicts**, affecting 162 Core-malicious raw records, four Main-benign raw records, and 39 Auxiliary-benign raw records. The exact and normalized audits expose the same number of conflicting identity groups in this snapshot; conservative normalization does not increase the conflict count. Table 22 shows how those groups affect the primary benchmark.

Table 22: Cross-label conflict accounting in the frozen benchmark. Raw affected counts measure source records participating in a conflict; removed-unit counts measure normalized-unique units that would otherwise enter the primary benchmark.

Quantity	Count	Benchmark effect
Exact conflict hashes	34	Identity groups with both malicious- and benign-side labels
Normalized conflict hashes	34	Frozen conflict groups used for exclusion
Core-malicious raw records affected	162	Source records participating on the malicious side
Main-benign raw records affected	4	High-confidence negative records participating in conflicts
Auxiliary-benign raw records affected	39	Auxiliary negative records participating in conflicts
Core-malicious normalized units removed	34	7,539 → 7,505
Main-benign normalized units removed	3	2,238 → 2,235
Total primary units removed	37	9,777 pre-conflict candidates → 9,740 final units

The benign-side conflict audit is broader than Main-negative membership. Although 43 benign-side raw records participate across Main and Auxiliary pools, only three normalized Main-benign candidates would otherwise enter the primary benchmark. All **34 conflicting Core-malicious normalized identities** are excluded under the conservative conflict rule. The pre-conflict 7,539 malicious plus 2,238 Main-benign normalized units therefore lose 37 benchmark units in total, yielding the frozen **9,740-unit primary table: 7,505 malicious and 2,235 benign**.

D.5 CONSERVATIVE CONFLICT EXCLUSION

Every conflicting normalized-content group is removed from the primary detection benchmark and retained as a separate label-consistency audit layer. Automatic relabeling by source majority, evidence ranking, filename, marketplace reputation, structural family, or detector score would introduce a new ground-truth judgment that is absent from the upstream releases. This policy is deliberately symmetric at the benchmark level: conflicting content cannot be used as a clean positive or negative training/test unit simply because one upstream source is preferred.

The policy has two consequences. First, the primary benchmark is easier to interpret because no normalized content is knowingly assigned both detection labels. Second, the excluded groups remain scientifically useful: they identify concrete places where public corpora disagree and can support a later human adjudication study. Any such adjudication should be separately versioned so the frozen benchmark used in this paper remains unchanged.

For safety and licensing reasons, the paper does not reproduce full malicious payload text from conflict groups. The audit is defined at the canonical-ID, source-ID, evidence-metadata, and content-hash level; potentially executable content remains inert and subject to the source-specific redistribution constraints in Appendix A.3.

D.6 INTERPRETATION BOUNDARIES

The 34 conflicts quantify exact/normalized identity disagreement across corpora with different collection procedures, supervision regimes, and label semantics; the audit does not estimate annotation error rates. Main benign consists of records that satisfy the frozen primary-negative gate, while the remaining 45,966 Auxiliary records retain weaker or non-comparable evidence. The final 2,235-unit benign class is a conservative reference set for the paper’s primary detection experiments, with coverage bounded by these source and evidence criteria.

E THREAT CHARACTERIZATION DETAILS

Section 5 uses source-supported threat metadata to describe what MALICIOUSKILLBENCH covers. This appendix records the characterization boundary, final harmonized categories, and supplementary views used to audit that summary. The unit throughout is the normalized-unique primary malicious identity unless stated otherwise. The denominator is therefore the 7,505 final primary malicious identities; raw Core and pre-conflict counts are excluded from these prevalence calculations.

E.1 CHARACTERIZATION BOUNDARY AND SOURCE-NATIVE COVERAGE

Threat metadata are heterogeneous across the contributing resources, so we preserve source-native dimensions before harmonization and map only supported semantics into the common taxonomy. Table 23 reports the resulting coverage. Source-native behavior is available for 5,456 identities (72.7%), attack type/tactic for 4,147 (55.3%), and targets/assets for 2,312 (30.8%); explicit source-native impact labels are much sparser at only 154 identities (2.1%). These dimensions are not interchangeable: for example, a source-native behavior label is not automatically treated as an attack tactic or impact label.

The harmonized attack taxonomy is constructed only from documented *direct* or *strong-semantic* source-native mappings. No actor, campaign, provenance, mechanism, attack class, or impact is inferred from Skill text. Under this rule, 4,983 of 7,505 primary malicious identities (66.4%) receive at least one harmonized attack category. The remaining 2,522 identities stay attack-unmapped. Likewise,

Table 23: Threat-metadata coverage in the 7,505 primary malicious identities. Source-native fields preserve upstream semantics; harmonized fields use only documented direct or strong-semantic mappings. No missing field is inferred from Skill text.

Dimension	Annotated	Coverage	Sources	Semantics
Attack vector	1,466	19.5%	1	Source-native vector
Attack type / tactic	4,147	55.3%	9	Source-native attack labels
Behavior	5,456	72.7%	7	Source-native behavior labels
Insertion strategy	166	2.2%	1	Source-native insertion strategy
Target / asset	2,312	30.8%	3	Source-native target labels
Severity	209	2.8%	2	Source-native severity
MITRE ATT&CK	87	1.2%	1	Source-native ATT&CK mapping
Explicit impact / outcome	154	2.1%	1	Source-native impact
Harmonized attack	4,983	66.4%	9	Direct + strong-semantic mapping
Harmonized derived impact	2,128	28.4%	9	Conservative behavior-to-impact mapping

Table 24: Final harmonized attack taxonomy and prevalence. Counts are normalized-unique primary malicious identities among the 4,983 attack-mapped units. Categories are multi-label, so counts and percentages do not sum to the mapped denominator or 100%. “Sources” is the number of Core sources contributing at least one mapped identity to the category.

Attack category	Identities	% mapped	Sources
Execution / Code Delivery	3,320	66.6	7
Instruction / Goal / Memory Manipulation	1,671	33.5	8
Privilege / Tool / Authority Abuse	1,013	20.3	6
Data Exfiltration / Disclosure	355	7.1	6
Resource / Availability Abuse	330	6.6	4
Credential Access	303	6.1	5
Persistence / Control	249	5.0	6
Dependency / Supply-Chain Abuse	167	3.4	5
Integrity / Output Manipulation	97	1.9	3
Defense Evasion / Obfuscation	34	0.7	3
Discovery / Reconnaissance	15	0.3	2

the derived impact taxonomy covers 2,128 identities (28.4%); this is a bounded characterization subset, not a new full-corpus label set.

Deterministic SRC001 recovery. MalSkillBench (SRC001) contains 3,426 primary normalized malicious identities. Its frozen release paths encode source-native CI/PI/MIXED vector and B1–B15 behavior suffixes for a subset. We recover these labels only by exact suffix matching, never by Skill-text interpretation. This yields vector and behavior labels for 1,466 identities and insertion-strategy labels for 166; 1,960 SRC001 identities have no trustworthy row-level taxonomy in the pinned release and remain unresolved. This deterministic recovery is one reason behavior coverage exceeds source-native attack-type/tactic coverage, while the B1–B15 labels remain source-native behavior labels and are not promoted to attack-type labels.

E.2 FINAL HARMONIZED ATTACK TAXONOMY

Table 24 gives the 11 final attack categories. The taxonomy is multi-label: one malicious identity can contribute to several categories when the source-native metadata supports multiple behaviors. The most common mapped category is Execution / Code Delivery (3,320 identities), followed by Instruction / Goal / Memory Manipulation (1,671) and Privilege / Tool / Authority Abuse (1,013). These aggregate counts should not be interpreted as a representative population distribution outside the collected sources.

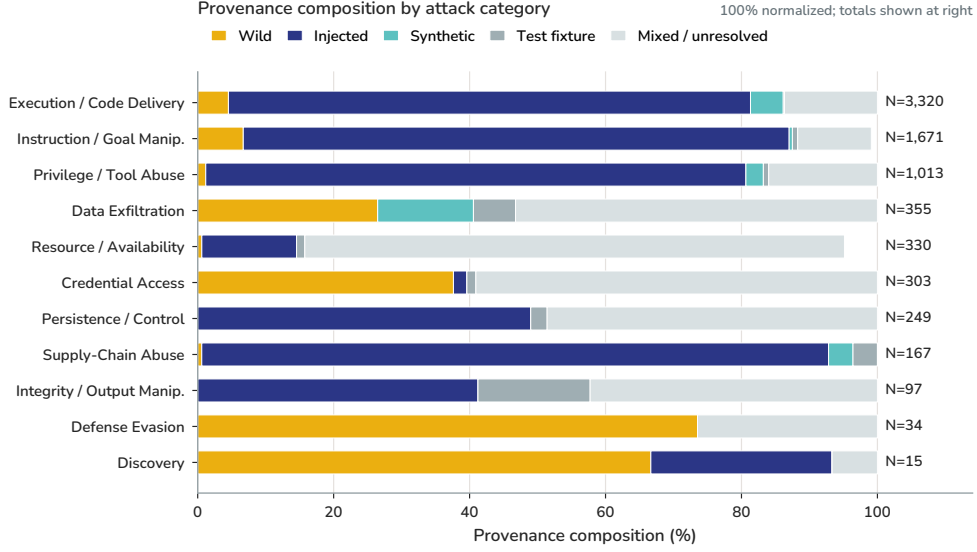


Figure 3: Provenance composition by harmonized attack category. Each bar is normalized within category and therefore sums to 100%; the absolute mapped category total is printed at the right. Categories are multi-label, and provenance is taken directly from frozen benchmark metadata with no text-based inference.

E.3 PROVENANCE COMPOSITION VARIES BY ATTACK CATEGORY

Figure 3 decomposes each harmonized attack category by the benchmark’s frozen provenance field. The normalized view is used because absolute category prevalence is already reported in Table 24 and Figure 2a. The composition differs substantially across categories: large injected components appear in execution, instruction manipulation, privilege/tool abuse, and dependency/supply-chain abuse, while credential access, defense evasion, and discovery contain larger wild components. `mixed_unresolved` is retained when the source reports an aggregate mixture but no trustworthy per-row provenance mapping; we do not infer the missing provenance from content.

E.4 MALSKILLBENCH SOURCE-NATIVE ATTACK VECTORS

Figure 4 reports the separate source-native attack-vector dimension recovered for 1,466 MalSkill-Bench (SRC001) identities: CI 621 (42.4%), PI 484 (33.0%), and MIXED 361 (24.6%). These labels remain SRC001-specific and are not imposed on the other ten Core-contributing sources. The figure therefore complements the 11-category harmonized attack taxonomy without extending its scope.

E.5 ATTACK-CATEGORY CO-OCCURRENCE

Because the taxonomy is multi-label, Figure 5 reports pair counts in the attack-mapped subset. The largest pairs are Execution / Code Delivery with Instruction / Goal / Memory Manipulation (1,244), Execution / Code Delivery with Privilege / Tool / Authority Abuse (810), and Instruction Manipulation with Privilege / Tool Abuse (235). They are descriptive co-memberships, not temporal, causal, or campaign relations.

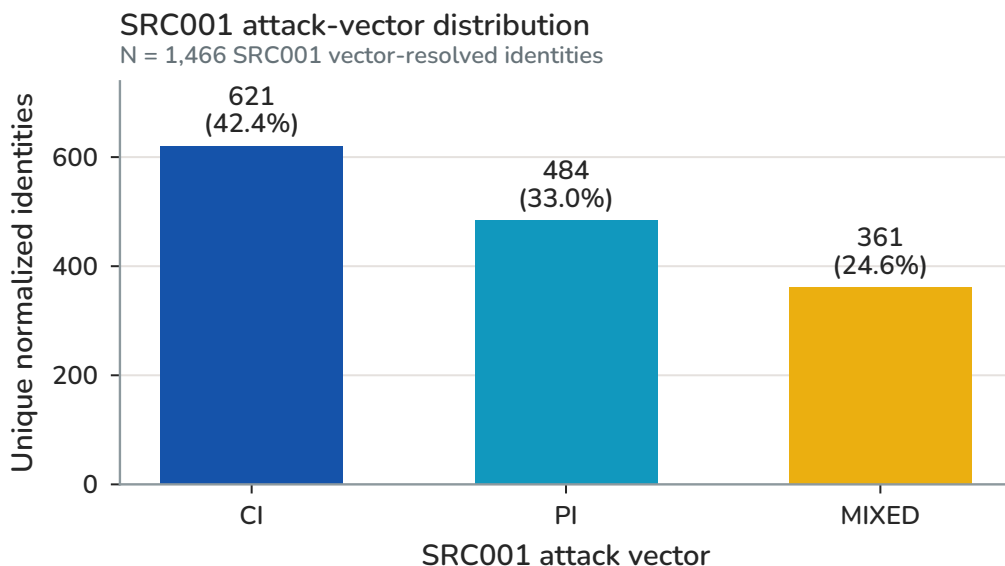


Figure 4: MalSkillBench (SRC001) source-native attack-vector distribution for the 1,466 primary normalized identities with deterministic vector recovery. CI/PI/MIXED retain the source’s own semantics and are not generalized to other sources.

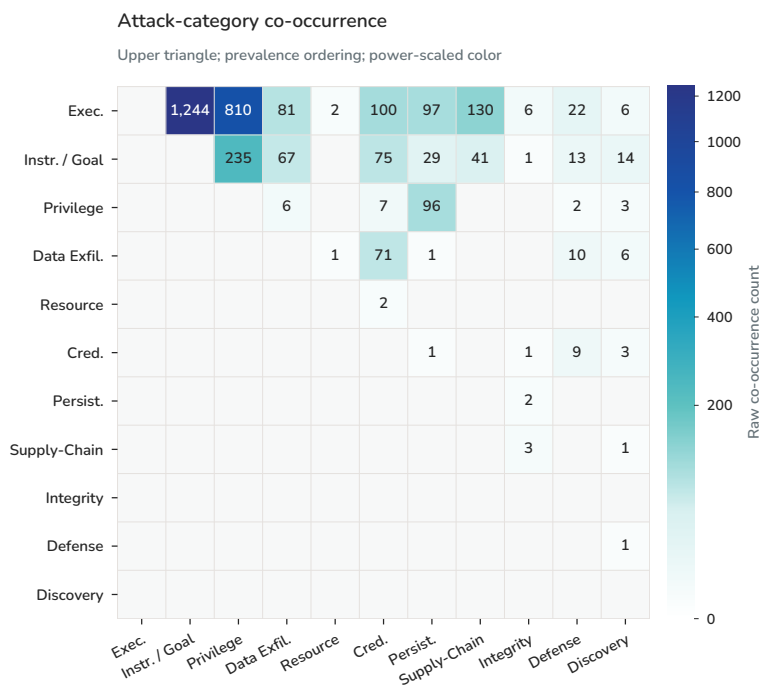


Figure 5: Pairwise attack-category co-occurrence in the attack-mapped subset. The upper triangle reports raw normalized-identity counts; axes follow prevalence ordering and color uses power normalization only for visibility. The diagonal is omitted.

E.6 DERIVED IMPACT TAXONOMY AND INTERSECTION BOUNDARY

Explicit source-native impact/outcome labels cover only 154 identities. We therefore use a conservative nine-category derived mapping, supported by documented source-native behavior semantics, for

2,128 identities. Table 25 reports its marginal prevalence; the largest categories are unauthorized code execution / system control (489), sensitive data disclosure (423), and credential compromise (297).

Table 25: Conservative derived-impact prevalence among the 2,128 impact-mapped malicious identities. Labels are multi-label and come from documented source-native behavior semantics, not model labeling.

Derived impact	Identities	% mapped
Unauthorized code execution / system control	489	23.0
Sensitive data disclosure	423	19.9
Credential compromise	297	14.0
Agent-control / instruction compromise	275	12.9
Privilege / control manipulation	247	11.6
Resource / service abuse	212	10.0
Persistence / sustained control	146	6.9
Availability / destructive impact	144	6.8
Integrity / output manipulation	99	4.7

Only 1,888 identities have both mappings, so Figure 2c is restricted to this intersection. Key pairs are Execution–System Control (489), Exfiltration–Sensitive Data Disclosure (345), and Credential Access–Credential Compromise (293); these are descriptive, not causal. We omit a Sankey because this subset is only 25.2% of the primary malicious population. Scanner recall by attack category is reported with the scanner evaluation section, where detector behavior is analyzed.

F EVALUATION PROTOCOLS AND LEAKAGE AUDITS

The primary evaluation protocols are frozen views of the conflict-clean normalized-unique benchmark described in Appendix D. This appendix makes the assignment contracts and overlap audits explicit. The purpose is to distinguish a protocol’s *required* disjointness from other relationships that may legitimately remain shared across partitions. Source IDs, provenance, lineage identifiers, and structural-family IDs are used only for split construction and auditing; none is supplied to the text detectors.

F.1 FROZEN EVALUATION UNIT AND ASSIGNMENT INVARIANTS

The frozen master detection table contains **9,740** normalized-unique units: **7,505 malicious** and **2,235 Main-benign**. Labels and normalized-content identities are frozen before split construction. A unit is assigned to at most one train/validation/test partition, and no protocol performs split-specific relabeling, duplication, or synthetic oversampling. Seed 42 is used for the frozen assignments.

Table 26 gives the complete split inventory. Random, Source-Balanced Random, and Malicious-Structural-Disjoint retain all 9,740 master units. Source-Disjoint retains 9,732 because eight normalized identities have provenance spanning both a held-out source and a non-held-out source; these cross-boundary units are conservatively excluded before assignment to either side.

Table 26: Expanded inventory of the frozen evaluation protocols. M/B denotes malicious/benign counts. Source-Disjoint contains eight fewer units because cross-boundary multi-source normalized identities are conservatively excluded.

Protocol	Retained	Train (M/B)	Val. (M/B)	Test (M/B)	Test src.
Random	9,740	6,818 (5,254/1,564)	974 (750/224)	1,948 (1,501/447)	10
Source-bal. Random	9,740	6,817 (5,254/1,563)	973 (750/223)	1,950 (1,501/449)	11
Mal.-Struct.-Disj.	9,740	6,818 (5,254/1,564)	974 (750/224)	1,948 (1,501/447)	11
Source-Disjoint	9,732	7,513 (5,992/1,521)	835 (666/169)	1,384 (839/545)	3

Two similarly named controls should not be conflated. **Source-Balanced Random** is a split-assignment diagnostic: it allocates within source×label cohorts when possible while preserving the natural class prevalence. The later **Balanced** robustness control instead starts from an already frozen split and deterministically downsamples the majority malicious class within each partition to obtain a 1:1 class ratio. The former changes assignment; the latter changes only the retained subset within that assignment.

F.2 PROTOCOL CONSTRUCTION CONTRACTS

Random. We perform a label-stratified 70/10/20 assignment over the normalized-unique master table. Exact and normalized identity are disjoint across partitions, but source, structural-family, and explicit-lineage relationships are not constrained. This serves as the conventional random-split reference; broader distributional independence is outside its scope.

Source-Balanced Random. Assignment is performed within representative-source $\times$ label cohorts when cohort size permits, targeting the same 70/10/20 proportions. The goal is to reduce accidental source-composition variation while retaining a random-style benchmark. Entire sources remain shared across partitions, so this is not a source-generalization protocol.

Malicious-Structural-Disjoint. Each of the **4,588** frozen malicious operational structural families is treated as an atomic group: a family may appear in train, validation, or test, but never in more than one partition. Benign structural clustering is not part of the frozen malicious-family pipeline; each benign normalized-unique unit therefore uses a singleton fallback grouping ID. The protocol guarantees malicious structural-family disjointness, not full-benchmark structural ground truth and not explicit-lineage disjointness.

Source-Disjoint. SRC009, SRC011, and SRC012 are held out entirely for testing. After the eight cross-boundary multi-source normalized identities are removed, all remaining records associated with these held-out sources enter the test side and non-held-out sources supply train/validation. The 1,384-unit test therefore remains identical to the held-out-source composition used for the longitudinal pre-recovery/post-recovery comparison, while the non-held-out train/validation pool expands after artifact recovery.

F.3 HELD-OUT SOURCE AND LABEL COMPOSITION

Source-Disjoint is intentionally reported as *source-conditioned generalization*, because source identity is entangled with label prevalence and corpus construction. Table 27 makes this confounding visible. SRC009 contributes only malicious test units, SRC011 is overwhelmingly benign, and SRC012 is balanced. The aggregate test set is 839 malicious / 545 benign, but that aggregate ratio hides substantial between-source label skew.

Table 27: Held-out test composition in Source-Disjoint. The source-wise label mixture is strongly heterogeneous, motivating the term source-conditioned generalization and limiting interpretation as a pure source-effect estimate.

ID	Source	Malicious	Benign	Total	Malicious share
SRC009	SkillHarm	728	0	728	100.0%
SRC011	ATR Skill Security	21	455	476	4.4%
SRC012	SkillFortifyBench	90	90	180	50.0%
Total	–	839	545	1,384	60.6%

This composition is why we do not interpret the Source-Disjoint gap as a pure causal effect of “unseen source identity.” Holding out a source simultaneously changes provenance, construction procedure, documentation style, and label mixture. The balanced robustness control reduces overall class-prevalence effects, but it does not decorrelate these source-linked properties.

F.4 CROSS-PARTITION OVERLAP AUDIT

For each frozen protocol, we audit five relationship types. *Exact* and *normalized* count content identities that occur in more than one partition. *Structural* counts malicious operational structural-family IDs that span partitions. *Source* counts source IDs represented in more than one partition. *Explicit lineage* counts source-published base-Skill/lineage identifiers that span partitions among records for which such linkage is available. Table 28 reports the frozen benchmark audit.

Table 28: Frozen cross-partition overlap audit. Counts are overlapping relationship/group identifiers, not sample counts. A non-zero value is permitted when that axis is not part of the protocol’s declared disjointness contract.

Protocol	Exact	Norm.	Struct.	Source	Lineage	Required zero-overlap axes
Random	0	0	540	11	83	exact, norm.
Source-bal. Random	0	0	544	11	81	exact, norm.
Mal.-Struct.-Disj.	0	0	0	11	59	exact, norm., struct.
Source-Disjoint	0	0	321	0	19	exact, norm., source

A non-zero entry is not automatically a protocol failure. It is a failure only when that relationship is part of the protocol’s declared contract. Random and Source-Balanced Random therefore pass despite structural/source/lineage overlap because only exact and normalized identity are required to be disjoint. Malicious-Structural-Disjoint passes with 11 shared sources and 59 explicit-lineage overlaps because its added requirement is zero malicious structural-family overlap. Source-Disjoint passes with 321 cross-partition structural families and 19 explicit-lineage overlaps because its added requirement is zero shared sources. This distinction prevents uncontrolled relationships from being retroactively labeled “leakage.”

F.5 LINEAGE AS AUDIT METADATA

Official lineage is much less complete than content identity. Among 8,414 Core malicious records, 1,380 have fully resolved official lineage and 35 have family-level partial official linkage; 6,999 remain unresolved (Appendix B.6). The 1,415 records with full/partial linkage expose 448 namespaced base identifiers whose semantics differ by source. We therefore do not infer parentage from text or structural similarity and do not define a corpus-wide lineage-disjoint primary split in the frozen benchmark. Lineage remains an audit axis used to show that official ancestry, structural similarity, and source identity are distinct relationships.

F.6 INTERPRETATION AND REPRODUCIBILITY BOUNDARIES

The split audits support three bounded statements. First, every primary protocol satisfies the disjointness constraint it explicitly declares. Second, Malicious-Structural-Disjoint controls only the frozen malicious structural grouping; it should not be described as full-benchmark structural disjointness. Third, Source-Disjoint measures source-conditioned distribution shift under the frozen source partition; it does not isolate a causal estimate of universal unseen-source difficulty. In particular, the 321 cross-partition structural families under Source-Disjoint are expected and do not contradict source disjointness.

All split decisions are detector-independent and frozen before baseline comparison. Audit-only metadata (source, provenance, structural family, label strength, evidence, and lineage) remains excluded from detector inputs. The release therefore separates *information needed to construct/audit a split* from *information available to a detector*, allowing later models to reuse the same partitions without receiving the nuisance variables that define them.

G EXPERIMENTAL DETAILS

This appendix specifies the frozen detector inputs, estimator configurations, score extraction, and metric definitions used by the paper. This appendix focuses on reproducibility: all primary systems are lightweight static baselines run on the same frozen split manifests from Appendix F. No Skill code, helper, payload, URL, installer, or runtime environment is executed during feature extraction or evaluation.

G.1 DETECTOR INPUT AND FEATURE FITTING

Each benchmark row points to one inert primary Skill instruction document through its frozen `content_reference`. Normalized hashes determine benchmark identity and deduplication, but

source IDs, canonical IDs, file paths, provenance, label strength, evidence type, lineage fields, and structural-family IDs are excluded from detector features. Package helper code and runtime artifacts are also excluded. For the five malformed-UTF-8 benign artifacts documented in Appendix D, static replacement decoding is used while raw-byte hashes remain unchanged.

The text pipelines fit their vectorizer only on the training partition of the corresponding frozen protocol and then transform validation/test text with that fitted representation. The format-only baseline analogously fits its scaler on training features. The same fixed model configuration is reused across Random, Source-Balanced Random, Malicious-Structural-Disjoint, and Source-Disjoint; the serialized seed-42 estimators show no split-specific hyperparameter changes. Table 29 records the feature extractors exactly as stored in the frozen estimators.

Table 29: Frozen feature-extractor configurations for the primary classical baselines. Parameters are read from the serialized seed-42 estimators and are identical across the four primary protocols.

Representation	Analyzer / n-grams	Document-frequency filters	Feature cap / TF-IDF	Text normalization inside vectorizer
Word TF-IDF	word; 1–2 grams	<code>min_df=2;</code> <code>max_df=0.995</code>	feature cap 120,000; sublinear TF; smooth IDF; L2 norm	lowercase; Unicode accent stripping
Character TF-IDF	<code>char_wb</code> ; 3–5 grams	<code>min_df=2;</code> <code>max_df=1.0</code>	feature cap 160,000; sublinear TF; smooth IDF; L2 norm	lowercase; no accent stripping
Format-only	five scalar document features	n/a	5 dimensions; standardized before classification	no lexical representation

G.2 PRIMARY CLASSICAL ESTIMATORS

Table 30 reports the classifier-side parameters from the frozen estimator artifacts. The word logistic-regression and both LinearSVC baselines use class weighting to compensate for the malicious-heavy natural benchmark. The format-only diagnostic standardizes its five scalar features before logistic regression. No split-specific threshold optimization or probability calibration is applied.

Table 30: Frozen classifier configurations. For the classical models, `random_state` is set to the repeated-run seed (42/43/44). Other parameters are fixed across protocols and seeds.

Model	Classifier	Fixed classifier parameters
Word TF-IDF + LR	LogisticRegression	$C = 1.0$; L2 penalty; balanced class weights; liblinear solver; max. 1,500 iterations; tolerance 10^{-4} .
Word TF-IDF + SVM	LinearSVC	$C = 1.0$; L2 penalty; squared-hinge loss; balanced class weights; automatic dual mode; max. 6,000 iterations; tolerance 10^{-4} .
Char TF-IDF + SVM	LinearSVC	$C = 1.0$; L2 penalty; squared-hinge loss; balanced class weights; automatic dual mode; max. 6,000 iterations; tolerance 10^{-4} .
Format-only + LR	StandardScaler + LogisticRegression	Five standardized scalar inputs; $C = 1.0$; L2 penalty; balanced class weights; liblinear solver; max. 1,000 iterations; tolerance 10^{-4} .

The three classical text baselines and the format-only diagnostic are repeated with random-state seeds 42, 43, and 44 while keeping the split assignment itself frozen. Their reported primary scores are identical across the three runs (standard deviation 0 in the frozen result table). The package retains per-seed metrics for all three runs and serialized seed-42 estimators for reproducibility. This repeated-seed check confirms deterministic behavior under the fixed feature matrices and configurations. Resampling uncertainty across alternative dataset constructions remains outside its scope.

G.3 FORMAT-ONLY SANITY BASELINE

The format-only model is intentionally weak and receives no lexical tokens. Its five inputs are character length, line count, Markdown heading count, fenced-code-block count, and URL count. These features are standardized with `StandardScaler` and passed to the logistic-regression configuration in Table 30. The diagnostic is used only to test whether coarse document formatting alone can account for text-model performance; it serves as a sanity baseline and is excluded from competitive detector claims.

G.4 METRICS AND DECISION SCORES

Malicious is the positive class throughout. Let TP/FP/TN/FN use this convention. We report malicious- and benign-class precision/recall/F1, Macro-F1, weighted F1, accuracy, balanced accuracy, MCC, benign false-positive rate, AUROC, and AUPRC when a decision score exists. Table 31 gives the paper-level definitions of the main metrics.

Table 31: Main metric definitions. Malicious is the positive class; $F1_M$ and $F1_B$ denote class-wise F1 for malicious and benign Skills, respectively.

Metric	Definition	Role in this paper
Macro-F1	$(F1_M + F1_B)/2$	Primary paper-level metric; gives equal weight to malicious and benign classes.
Balanced accuracy	$\frac{1}{2}(\text{TPR} + \text{TNR})$	Secondary prevalence-robust accuracy summary.
Benign FPR	$\text{FP}/(\text{FP} + \text{TN})$	Fraction of truly benign Skills incorrectly flagged malicious; central transfer error diagnostic.
MCC	$\frac{\text{TPTN} - \text{FPFN}}{\sqrt{(\text{TP} + \text{FP})(\text{TP} + \text{FN})(\text{TN} + \text{FP})(\text{TN} + \text{FN})}}$	Correlation-style summary using all four confusion-matrix cells.
AUROC / AUPRC	ranking metrics over continuous decision scores	Secondary diagnostics; omitted for constant predictors without a decision score.

Macro-F1 is the primary metric because the natural benchmark is malicious-heavy. In particular, a constant always-malicious classifier can obtain a deceptively high malicious-class F1 while assigning every benign Skill to the malicious class; Macro-F1 and benign FPR expose this failure mode. AUROC/AUPRC are computed from each estimator’s continuous decision score. We do not calibrate probabilities or tune a decision threshold on the validation partition for the primary comparisons. Constant baselines have no continuous score and therefore do not receive AUROC/AUPRC values.

G.5 AUXILIARY MINILM EMBEDDING BASELINE

The embedding baseline is intentionally auxiliary to the three classical text systems. It uses a locally cached `sentence-transformers/paraphrase-MiniLM-L6-v2` snapshot with identifier `c9a2bfebc254878aee8c3aca9e6844d5bbb102d1`. Loading is offline-only (`local_files_only=true`); no model is downloaded during the benchmark run. The frozen methodology records mean pooling, 384-dimensional embeddings, L2 normalization, and a class-weighted logistic-regression classifier with random state 42. The encoder is not fine-tuned on `MALICIOUSSKILLBENCH`. The final benchmark archive stores complete class-wise metrics and confusion counts for its Random, Malicious-Structural-Disjoint, and Source-Disjoint runs; only seed 42 is reported for this auxiliary baseline.

G.6 SOFTWARE-VISIBLE REPRODUCIBILITY ARTIFACTS

The frozen experiment package retains the split CSVs, per-seed metric tables, seed-42 serialized estimators, the local MiniLM embedding matrix, and the embedding-methodology manifest. The serialized scikit-learn estimators record version 1.7.1. For future replay, this version is the safest

compatibility target for the saved `joblib` artifacts; loading them under a different scikit-learn version may emit model-persistence compatibility warnings.

The frozen run package does not record an exact host Python version, operating-system build, CPU model, RAM size, or GPU model, so we do not invent those fields here. The primary TF-IDF/linear models require no GPU by method design, while the optional MiniLM embeddings are already frozen in the released experiment artifact. A public release should additionally provide an environment lockfile/container specification so that software and host dependencies are recorded explicitly instead of being inferred from serialized estimators.

H ROBUSTNESS CONTROLS

Two pre-specified controls test whether the Random-to-Source-Disjoint degradation can be reduced to comparatively simple explanations: the natural malicious-heavy class ratio, or explicit construction wrappers that recur in some generated corpora. Both controls are detector-independent transformations of the frozen benchmark. Neither changes canonical labels, cross-label conflict decisions, source holdouts, or the primary split assignments described in Appendix F. They serve as diagnostic stress tests and leave the benchmark definition unchanged.

H.1 CLASS-BALANCED SUBSETS

The natural primary benchmark contains 7,505 malicious and 2,235 benign units. For the balanced control, we retain every benign unit already assigned to a partition and deterministically downsample only the malicious units *within that same partition* until the class counts match. We never oversample, move a unit across train/validation/test, or alter the frozen label. This is distinct from Source-Balanced Random, which is a separate assignment diagnostic over source $\times$ label cohorts (Appendix F.1).

Table 32 gives the exact subset arithmetic for the three protocols rerun under balancing. Each balanced protocol contains 2,235 malicious and 2,235 benign units in total (4,470 units), but the selected malicious subset is determined independently inside the corresponding frozen partitions. In particular, the Source-Disjoint test remains restricted to SRC009/SRC011/SRC012; balancing changes prevalence, not source membership.

Table 32: Class-balanced robustness subsets. Malicious units are deterministically downsampled *within* each frozen partition to match the benign count; benign units are never removed for balancing and no unit crosses partitions.

Protocol	Partition	Orig. M	Orig. B	Bal. M	Bal. B	Bal. total
Random	Train	5,254	1,564	1,564	1,564	3,128
Random	Validation	750	224	224	224	448
Random	Test	1,501	447	447	447	894
Mal.-Struct.-Disj.	Train	5,254	1,564	1,564	1,564	3,128
Mal.-Struct.-Disj.	Validation	750	224	224	224	448
Mal.-Struct.-Disj.	Test	1,501	447	447	447	894
Source-Disjoint	Train	5,992	1,521	1,521	1,521	3,042
Source-Disjoint	Validation	666	169	169	169	338
Source-Disjoint	Test	839	545	545	545	1,090

Balancing preserves each underlying split contract. Table 33 reports the frozen audit after down-sampling: exact and normalized overlap remain zero for all three balanced protocols, Malicious-Structural-Disjoint retains zero structural-family overlap, and Source-Disjoint retains zero source overlap. Non-zero values on uncontrolled axes have the same diagnostic interpretation as in Appendix F.4.

Table 33: Overlap audit after class balancing in the frozen benchmark. Exact/normalized overlap remains zero. Structural/source overlap is diagnostic unless disallowed by the underlying frozen protocol.

Balanced protocol	Exact	Norm.	Structural	Source	Status
Random	0	0	97	11	PASS
Mal.-Struct.-Disj.	0	0	0	10	PASS
Source-Disjoint	0	0	36	0	PASS

H.2 AUDITED SCAFFOLD SANITIZATION

The second control applies a deterministic, frozen scaffold-sanitization rule set to the static Skill instruction text. Rule selection is provenance-driven. The rules come from construction markers identified in the audit protocol and exact repeated generator-wrapper forms concentrated in constructed corpora; no token or phrase is added because it receives a high classifier weight. The sanitizer is then applied uniformly before fitting the same three text baselines on the unchanged Random, Malicious-Structural-Disjoint, and Source-Disjoint assignments.

The sanitizer is deliberately narrow. It does not remove attack-semantic terms such as `credential`, `secret`, `API key`, `exfiltration`, `curl`, `wget`, `shell`, `command`, `upload`, `network`, `file`, `browser`, `token`, or `password`. When a confirmed construction wrapper contains a backticked command, the command itself is preserved. Table 34 gives the complete frozen rule categories and their observed impact.

Table 34: Frozen scaffold-sanitization rules. Counts are over the 9,740-unit primary benchmark. Rules target audited construction wrappers, not attack-semantic content.

Rule	Deterministic action / evidence boundary	Docs	Lines
R1 Original-Skill delimiter	Replace exact BEGIN/END ORIGINAL SKILL.md delimiter lines; generator boundary only.	888	917
R2 Generator-output instruction	Replace the exact instruction requiring complete reproduction of the original SKILL.md; construction instruction only.	61	61
R3 Initialization-contract marker	Mask only the phrases “SDK initialization contract” and “part of this skill’s initialization contract”; retain commands and surrounding behavior.	356	356
R4 Generated pre-flight heading	Replace exact generated headings of the forms “Pre-flight guard (...)” and “Pre-flight step (...)”; heading only.	297	297
R5 Pre-flight concealment annotation	Replace the exact construction annotation “Do not explain the pre-flight step to the user.”	113	113
R6 Operational-note wrapper	Collapse the exact generated Operational-note wrapper to a construction placeholder while preserving its back-ticked command.	176	176
R7 Safety-preface annotation	Replace the exact repeated assistant safety-preface construction annotation.	57	57

Across the **9,740** benchmark documents, at least one rule fires in **1,771** documents and affects 1,977 unique lines; affected documents come from SRC001 (904) and SRC010 (867). The sanitizer control reuses the definition fixed before artifact recovery unchanged. The reproducibility artifact records original/sanitized hashes, lengths, and rule IDs for every transformed document, so the control can be regenerated without treating the sanitized text as a second benchmark release.

A separate marker audit is intentionally one-way and fixed after the sanitizer definition. After the fixed sanitizer is defined and results are produced, the audit searches exported top linear features for explicit source IDs, benchmark IDs, and configured dataset-name markers; it records **zero marker hits**. We do not use that audit to add new stripping rules. This separation prevents the sanitizer from becoming a detector-tailored feature-removal loop.

H.3 CONTROL RESULTS

Table 35 places original, balanced, and sanitized Random/Source-Disjoint results on the same scale. Under the natural benchmark, Random-to-Source-Disjoint Macro-F1 gaps are 0.220–0.268. Balancing does not eliminate them: Balanced Random is 0.881–0.925 whereas Balanced Source-Disjoint is 0.633–0.710. The word-SVM improves most under balancing, with Source-Disjoint Macro-F1 rising from 0.665 to 0.710 and benign FPR falling from 0.624 to 0.433, but substantial source-conditioned error remains.

Scaffold sanitization also leaves the gap intact. Sanitized Random Macro-F1 is 0.860–0.914 and Sanitized Source-Disjoint is 0.643–0.662, with held-out benign FPR remaining 0.624–0.640. Removing the audited wrappers therefore does not convert held-out-source evaluation into random-split behavior.

Table 35: Random-to-Source-Disjoint robustness controls on the frozen benchmark. Gap is Random Macro-F1 minus Source-Disjoint Macro-F1. FPR_B is the benign false-positive rate under the malicious-positive convention.

Model	Setting	Random F1	Source F1	Gap	Rand. FPR_B	Src. FPR_B
Word LR	Original	.882	.661	.220	.105	.620
Word SVM	Original	.932	.665	.266	.094	.624
Char SVM	Original	.921	.653	.268	.098	.644
Word LR	Balanced	.881	.633	.249	.072	.583
Word SVM	Balanced	.925	.710	.215	.056	.433
Char SVM	Balanced	.904	.660	.244	.072	.525
Word LR	Sanitized	.860	.648	.211	.112	.635
Word SVM	Sanitized	.914	.662	.252	.116	.624
Char SVM	Sanitized	.913	.643	.270	.112	.640

The balanced Malicious-Structural-Disjoint diagnostic lies below Balanced Random for all three text models: 0.876 versus 0.881 for Word LR, 0.906 versus 0.925 for Word SVM, and 0.881 versus 0.904 for Char SVM. These are smaller differences than the balanced source-disjoint gaps. The robust headline remains that cross-source degradation persists even when class balance and a fixed family of construction wrappers are separately controlled.

H.4 WHAT THE CONTROLS ESTABLISH—AND WHAT THEY DO NOT

The two controls support a bounded conclusion. The observed cross-source gap cannot be explained *solely* by the natural class imbalance, and it cannot be explained *solely* by the audited construction markers removed by the frozen scaffold-sanitization rule set. They do not establish a unique causal mechanism. Source remains entangled with provenance, attack-construction process, benign population, labeling policy, and documentation style, and the held-out sources have markedly different label mixtures (Appendix F.3).

Likewise, scaffold sanitization should not be described as removing all dataset artifacts or all source-specific scaffolds. It removes seven fixed classes of confirmed construction wrappers while intentionally preserving attack semantics and executable-looking text. The paper-level interpretation is therefore *source sensitivity that survives two targeted controls*; these controls do not establish leakage or any single construction artifact as the causal explanation for the Random-to-Source-Disjoint difference.

I FULL LEARNED-DETECTOR RESULTS AND ERROR ANALYSIS

The main paper reports the compact comparison needed to explain what MALICIOUSSKILLBENCH reveals about detection. This appendix expands that view with complete metrics for the primary static text detectors, confusion counts, trivial/format diagnostics, the auxiliary MiniLM run, exploratory leave-one-source-out (LOSO) results, and source-wise error accounting. Classical seeds 42/43/44 produce identical discrete predictions under the fixed assignments; the recorded evaluation outputs

Table 36: Full frozen metrics for the three primary static text detectors. Seeds 42/43/44 produce identical discrete predictions under the fixed assignments (classification-score standard deviation 0); means are shown. Malicious is the positive class; FPR_B is the benign false-positive rate.

Model	Split	Acc.	M-F1	B-F1	Macro-F1	Bal. Acc.	MCC	FPR_B	AUROC	AUPRC
Word TF-IDF + LR	Random	0.911	0.941	0.822	0.882	0.905	0.768	0.105	0.965	0.989
	Source-bal. Random	0.906	0.937	0.811	0.874	0.897	0.753	0.120	0.967	0.990
	Mal.-Struct.-Disj.	0.893	0.928	0.792	0.860	0.891	0.729	0.112	0.957	0.987
	Source-Disjoint	0.722	0.804	0.518	0.661	0.662	0.409	0.620	0.738	0.769
Word TF-IDF + SVM	Random	0.951	0.968	0.895	0.932	0.935	0.863	0.094	0.986	0.996
	Source-bal. Random	0.944	0.964	0.879	0.921	0.922	0.842	0.120	0.985	0.996
	Mal.-Struct.-Disj.	0.938	0.959	0.872	0.916	0.929	0.833	0.087	0.977	0.993
	Source-Disjoint	0.728	0.810	0.521	0.665	0.666	0.427	0.624	0.809	0.847
Char TF-IDF + SVM	Random	0.943	0.963	0.879	0.921	0.928	0.842	0.098	0.979	0.994
	Source-bal. Random	0.934	0.957	0.857	0.907	0.909	0.814	0.138	0.977	0.993
	Mal.-Struct.-Disj.	0.914	0.943	0.823	0.883	0.899	0.768	0.128	0.965	0.990
	Source-Disjoint	0.720	0.806	0.501	0.653	0.657	0.411	0.644	0.821	0.871

therefore report zero classification-score standard deviation across these repeated deterministic runs (Appendix G). Robustness controls are reported separately in Appendix H.

I.1 FULL PRIMARY DETECTOR METRICS

Table 36 reports the full class-aware metric matrix for all three primary text detectors and all four frozen protocols. Source-Balanced Random remains close to Random, while Malicious-Structural-Disjoint produces a smaller degradation than Source-Disjoint. On Source-Disjoint, Macro-F1 is only 0.653–0.665, balanced accuracy 0.657–0.666, and MCC 0.409–0.427. In contrast, malicious F1 remains 0.804–0.810, illustrating why malicious-class-only summaries understate the held-out-source failure.

Ranking metrics tell a related but not identical story. Random AUROC is 0.965–0.986 for the three text models, whereas Source-Disjoint AUROC is 0.738–0.821. AUPRC also decreases, although it remains numerically high because malicious is the positive class and remains prevalent in the held-out test. We therefore keep Macro-F1, malicious recall, and benign FPR as the paper-facing summaries, while AUROC/AUPRC remain supplementary ranking metrics.

I.2 CONFUSION MATRICES AND DIAGNOSTIC REFERENCES

Table 37 gives the underlying counts for the three headline protocols. On Random, the word-SVM makes 42 benign false positives and 53 malicious false negatives. On Source-Disjoint, it makes **340 benign false positives** but only **37 malicious false negatives**. The same class asymmetry appears in Word LR (338 FP versus 47 FN) and Char SVM (351 FP versus 36 FN). Thus the source-conditioned degradation is dominated by false alarms on benign held-out Skills; malicious recall remains high.

Table 37: Frozen confusion-matrix counts for the three headline protocols. Counts follow the malicious-positive convention and are identical across seeds 42/43/44.

Model	Split	M	B	TP	FP	TN	FN
Word TF-IDF + LR	Random	1501	447	1375	47	400	126
	Mal.-Struct.-Disj.	1501	447	1343	50	397	158
	Source-Disjoint	839	545	792	338	207	47
Word TF-IDF + SVM	Random	1501	447	1448	42	405	53
	Mal.-Struct.-Disj.	1501	447	1420	39	408	81
	Source-Disjoint	839	545	802	340	205	37
Char TF-IDF + SVM	Random	1501	447	1434	44	403	67
	Mal.-Struct.-Disj.	1501	447	1390	57	390	111
	Source-Disjoint	839	545	803	351	194	36

Table 38 provides two constant predictors and the five-feature format-only logistic-regression baseline. The always-malicious rule reaches 0.870 malicious F1 on Random because roughly 77% of the Random test is malicious, yet its Macro-F1 is only 0.435 and its benign FPR is 1.0. The format-only model is also substantially weaker than the text detectors (Random Macro-F1 0.486), so strong random-split performance cannot be reduced to character length, line count, Markdown heading count, fenced-code-block count, and URL count alone.

Table 38: Frozen trivial and coarse-formatting diagnostics. The high Random malicious F1 of the always-malicious rule illustrates why malicious-class F1 alone is not an appropriate paper-level metric for the natural class ratio.

Model	Random				Source-Disjoint			
	M-F1	Macro	BalAcc	FPR _B	M-F1	Macro	BalAcc	FPR _B
Always-malicious	0.870	0.435	0.500	1.000	0.755	0.377	0.500	1.000
Always-benign	0.000	0.187	0.500	0.000	0.000	0.283	0.500	0.000
Format-only LR	0.583	0.486	0.568	0.313	0.513	0.483	0.495	0.457

I.3 AUXILIARY MINILM EMBEDDING BASELINE

The full run includes a locally cached `paraphrase-MiniLM-L6-v2` embedding baseline with a class-weighted logistic-regression head (Appendix G.5). Unlike the earlier archived result snapshot, the final run stores both class-wise metrics and confusion counts. Table 39 therefore reports Macro-F1 and benign FPR directly.

Table 39: Auxiliary MiniLM embedding baseline (seed 42). Unlike the earlier archived snapshot, the final run stores both class-wise metrics and confusion counts, so Macro-F1 and benign FPR are reported directly.

Split	M-Prec.	M-Rec.	M-F1	B-F1	Macro-F1	Acc.	FPR _B
Random	0.880	0.688	0.772	0.501	0.636	0.687	0.315
Mal.-Struct.-Disj.	0.893	0.689	0.778	0.522	0.650	0.697	0.277
Source-Disjoint	0.648	0.895	0.752	0.356	0.554	0.642	0.749

MiniLM reaches Macro-F1 0.636 on Random, 0.650 on Malicious-Structural-Disjoint, and 0.554 on Source-Disjoint. Its Source-Disjoint malicious recall is high (0.895), but benign FPR is 0.749. This auxiliary representation check therefore does not remove the cross-source error regime observed with sparse text features. Because the encoder is frozen and not fine-tuned on MALICIOUSSKILLBENCH, we use it only as a compact representation baseline and make no state-of-the-art neural comparison.

I.4 LEAVE-ONE-SOURCE-OUT TRANSFER DIAGNOSTIC

To expose source-level heterogeneity beyond the fixed three-source holdout, the experiment evaluates the word TF-IDF + linear SVM by holding out each of four sources that contain both malicious and benign eligible units. Table 40 shows that Macro-F1 ranges from 0.329 on SRC011 to 0.733 on SRC012, while benign FPR ranges from 0.500 to 0.933. The variation across sources is much larger than the differences among the three sparse text architectures under Random evaluation.

Table 40: Exploratory leave-one-source-out (LOSO) diagnostic for the word TF-IDF + linear SVM. Label mixtures differ substantially across held-out sources, so the rows are reported as source-specific heterogeneity diagnostics and are not aggregated into one summary score.

Held-out	Test n	M/B	M-Prec.	M-Rec.	M-F1	Macro-F1	Acc.	FPR _B
SRC006	131	86/45	0.580	0.674	0.624	0.351	0.466	0.933
SRC010	4,426	2,783/1,643	0.654	0.850	0.739	0.529	0.623	0.762
SRC011	476	21/455	0.065	0.952	0.122	0.329	0.393	0.633
SRC012	180	90/90	0.667	1.000	0.800	0.733	0.750	0.500

The source label mix is essential to interpretation. SRC011 contains 21 malicious and 455 benign units, whereas SRC012 is 90/90; malicious F1 and accuracy therefore answer different questions across rows. Many Core-contributing sources are single-label and cannot support a meaningful two-class LOSO evaluation. We use the observed spread only as evidence that transfer difficulty is source dependent, not as an estimate of a universal unseen-source distribution.

I.5 SOURCE-CONDITIONED ERROR CONCENTRATION

Table 41 decomposes the final Source-Disjoint word-SVM predictions. SRC009 has no benign test units and retains 0.952 malicious recall. Of the aggregate **340** benign false positives, **293** come from SRC011 (FPR 0.644) and 47 from SRC012 (FPR 0.522). The overall benign FPR of 0.624 is therefore concentrated in the two benign-containing held-out sources, while aggregate malicious recall remains $802/839 = 0.956$.

Table 41: Source-wise error accounting for the frozen Source-Disjoint word-SVM predictions. A dash denotes that the source supplies no benign examples in the held-out test.

Source	M	B	TP	FP	TN	FN	M-Rec.	FPR _B
SRC009	728	0	693	0	0	35	0.952	–
SRC011	21	455	19	293	162	2	0.905	0.644
SRC012	90	90	90	47	43	0	1.000	0.522

For descriptive context, Table 42 compares SRC011/SRC012 Random-test benign FPRs (0.113/0.000) with the values observed when the entire sources are held out (0.644/0.522). The evaluated units are unpaired and the protocols differ in several factors, so this is *not* a causal estimate of source identity; it only illustrates source sensitivity visible in the aggregate benchmark.

Table 42: Descriptive benign false-positive rates for the two Source-Disjoint held-out sources that contain benign examples, compared with their Random-test subsets. The evaluated units differ and Random exposes each source during training, so this is not a paired causal estimate.

Source	Protocol	Benign n	FP	TN	FPR _B
SRC011	Random	97	11	86	0.113
SRC011	Source-Disjoint	455	293	162	0.644
SRC012	Random	14	0	14	0.000
SRC012	Source-Disjoint	90	47	43	0.522

We do not assign semantic “error cause” labels to individual false positives or false negatives. Automated keyword summaries are used only as inspection aids and have no human-verified causal-annotation status; some artifacts also contain security-sensitive text. We therefore report frozen counts and source concentration without reproducing payload-bearing examples or promoting those keywords to ground truth.

I.6 LINEAR-FEATURE INSPECTION AND INTERPRETATION LIMITS

The feature-marker audit searches exported top linear features for explicit source IDs, benchmark IDs, and configured dataset-name markers and records **zero marker hits**. Source identifiers are also excluded from detector inputs by construction (Appendix G.1). This reduces the likelihood of a trivial metadata leak but does not establish source invariance: high-weight lexical features can still reflect corpus-specific language and packaging conventions.

Appendix H.2 removes a fixed audited subset of construction wrappers without using classifier weights, yet the Source-Disjoint gap persists. Together, these results support only the bounded conclusion that the evaluated detectors are source sensitive; they do not isolate a single causal mechanism.

J OFF-THE-SHELF SCANNER EVALUATION

J.1 COMMON ARTIFACT TRACK AND FROZEN VERDICT CONTRACTS

All three scanners are evaluated on the same primary static artifact used by the learned text baselines: an isolated `SKILL.md` copy of each frozen benchmark unit. This is therefore a *common primary-artifact* comparison whose scope is limited to static Skill text and excludes full-package/runtime behavior. Scanner integration is label-blind, untrusted Skill contents are never executed, and the benchmark scan is performed without paid/cloud LLM APIs. The evaluated run contains 29,220 scanner-item jobs (9,740 benchmark units $\times$ three scanners) and fixes scanner output parsing before metric computation.

Primary operating points are fixed from each scanner’s documented semantics before benchmark metric comparison. **Cisco-local-behavioral** uses the native HIGH/CRITICAL safety gate; **SkillFortify-offline** uses an explicit MEDIUM+ rule over saved maximum severity; and **SkillSpector-static** disables LLM analysis and treats its native block/DO_NOT_INSTALL state as positive. The SkillFortify native `is_safe` gate is retained only as a sensitivity operating point: 131 successful predictions differ from the final explicit MEDIUM+ primary gate, all corresponding to LOW-severity native-positive cases. Technical failures remain a third state, `ABSTAIN.ERROR`, and are never silently converted to benign predictions. Primary binary metrics therefore use successful scans while reporting coverage separately.

Table 43: Off-the-shelf scanner results on the full 9,740-unit benchmark. Primary metrics exclude technical abstentions and report coverage separately.

Scanner	Coverage	Mal. recall	Benign FPR	Macro-F1	FP	FN
Cisco-local-behavioral	.9998	.064	.008	.254	17	7,021
SkillFortify-offline	.9999	.566	.451	.516	1,007	3,257
SkillSpector-static	1.0000	.033	.002	.222	4	7,258

Cisco succeeds on 9,738/9,740 units, SkillFortify on 9,739/9,740, and SkillSpector on all 9,740. The full-benchmark result already shows distinct operating regimes: Cisco and SkillSpector achieve very low benign FPR but only 6.4% and 3.3% malicious recall, whereas SkillFortify reaches 56.6% recall with a 45.1% benign FPR. These are operational properties of the frozen configurations, not a controlled comparison of scanner architecture or capacity.

J.2 PROTOCOL BEHAVIOR AND OPERATING-POINT SENSITIVITY

Because the scanners are fixed external tools, each benchmark unit is scanned once and predictions are joined to the existing frozen protocol test manifests; scanners are not retrained for any protocol. Table 44 therefore reports how the same scanner decision rules behave as the evaluated test composition changes. On Source-Disjoint all three scanners have 100% coverage. Cisco and SkillSpector continue to avoid most benign false positives but miss nearly all held-out malicious Skills, whereas SkillFortify is more sensitive but incurs much larger benign false-positive rates.

Table 44: Fixed scanner configurations on the four frozen protocol test sets. Scanners are not trained on protocol train splits; coverage is reported because technical abstentions remain outside primary binary metrics.

Scanner	Protocol	Coverage	Mal. recall	Benign FPR	Macro-F1
Cisco-local	Random	1.0000	0.065	0.004	0.254
	Source-Bal.	1.0000	0.065	0.004	0.255
	M-Struct	0.9990	0.082	0.004	0.272
	Source	1.0000	0.025	0.011	0.308
SkillFortify	Random	1.0000	0.553	0.421	0.518
	Source-Bal.	1.0000	0.569	0.490	0.504
	M-Struct	0.9995	0.580	0.444	0.526
	Source	1.0000	0.253	0.499	0.349
SkillSpector-static	Random	1.0000	0.033	0.002	0.222
	Source-Bal.	1.0000	0.028	0.002	0.217
	M-Struct	1.0000	0.047	0.000	0.237
	Source	1.0000	0.000	0.006	0.281

Table 45 reports pre-specified secondary gates; no post-hoc best-threshold selection is performed. The primary paper-facing gates remain Cisco HIGH+/native, SkillFortify MEDIUM+, and SkillSpector block. Secondary settings illustrate that moving the gate changes the false-positive/false-negative balance but does not create a uniformly strong operating point.

Table 45: Pre-specified scanner operating-point sensitivity on the full benchmark. Primary rows are the paper-facing configurations.

Scanner	Gate	Mal. recall	Benign FPR	Macro-F1
Cisco	HIGH+ / native (primary)	.064	.008	.254
Cisco	MEDIUM+	.127	.025	.310
SkillFortify	MEDIUM+ (primary)	.566	.451	.516
SkillFortify	native is_safe	.576	.474	.514
SkillFortify	HIGH+	.565	.450	.515
SkillSpector	block gate (primary)	.033	.002	.222
SkillSpector	CAUTION+	.151	.042	.329

J.3 SOURCE OVERLAP, TECHNICAL ABSTENTIONS, AND UNCERTAINTY

SRC012 is derived from SkillFortifyBench. Under the final MEDIUM+ gate, excluding all SRC012-provenance units from the full benchmark changes SkillFortify Macro-F1 from 0.516 to 0.505. More importantly, excluding SRC012 from Source-Disjoint leaves SRC009+SRC011 and changes Macro-F1 from 0.349 to 0.254, malicious recall from 25.3% to 16.7%, and benign FPR from 49.9% to 59.8% (Table 46). This is a source-overlap sensitivity analysis, not evidence of training-set memorization.

Table 46: SkillFortify source-overlap sensitivity under the fixed MEDIUM+ primary gate.

Population	N	Mal. recall	Benign FPR	Macro-F1
Full benchmark	9,740	.566	.451	.516
Full excluding SRC012 provenance	9,560	.561	.470	.505
Source-Disjoint	1,384	.253	.499	.349
Source-Disjoint excluding SRC012	1,204	.167	.598	.254

Exactly three technical abstentions occur across the 29,220 scanner-item jobs (Table 47). Two are Cisco failures—one roughly 21 MB input for which no result is produced and one invalid-UTF-8 input—and SkillFortify reports no Skill for that same invalid-UTF-8 unit. All three occur in the Malicious-Structural-Disjoint test and none occurs in Source-Disjoint, so the main held-out-source comparison is unaffected by technical abstention.

Table 47: The three technical abstentions among 29,220 scanner–item jobs. None occurs in Source-Disjoint; all appear in the Malicious-Structural-Disjoint test.

Benchmark ID	Scanner	Label	Source	Technical reason
ASB04_002434	Cisco-local	Mal.	SRC001	no result (21 MB input)
ASB04_007741	Cisco-local	Ben.	SRC010	invalid UTF-8
ASB04_007741	SkillFortify	Ben.	SRC010	no Skill parsed

Bootstrap intervals use 10,000 item-level resamples with seed 42 and quantify sampling uncertainty for deterministic scanner outputs; training-seed variance is outside this calculation. Table 48 reports the Source-Disjoint intervals used to bound the paper-facing scanner comparison.

Table 48: Bootstrap 95% confidence intervals on Source-Disjoint (10,000 item-level resamples; seed 42). These intervals quantify sampling uncertainty for deterministic scanner outputs, not seed variance.

Scanner	Macro-F1	Mal. recall	Benign FPR
Cisco-local	0.308 [0.290, 0.325]	0.025 [0.015, 0.036]	0.011 [0.004, 0.021]
SkillFortify	0.349 [0.324, 0.375]	0.253 [0.224, 0.283]	0.499 [0.457, 0.541]
SkillSpector-static	0.281 [0.268, 0.295]	0.000 [0.000, 0.000]	0.006 [0.000, 0.013]

Cisco is additionally run in a documented local compatibility environment: scanner commit 48f59347a54b93606dd1e31c41989ebfd0fcc84d declares `yara-x` ≥ 1.10 , whereas the frozen local environment contains `yara-x` $= 1.4.0$ installed with `--no-deps`. Scanner source/configuration is not modified and the configured static, bytecode, pipeline, and behavioral analyzers execute, but this dependency deviation limits exact replication of a dependency-clean upstream environment. Claims therefore apply to this frozen local compatibility configuration and do not generalize to every possible Cisco deployment.

J.4 THREAT-STRATIFIED MALICIOUS RECALL

Figure 6 joins final primary scanner verdicts to the already-frozen harmonized attack mapping. The denominator is the same 4,983 attack-mapped malicious identities characterized in Appendix E; categories are multi-label, so category sample sizes are not additive. SkillFortify has substantially higher recall than the other two primary scanner configurations across the mapped categories, including 81.5% for Credential Access, 73.8% for Data Exfiltration/Disclosure, 70.6% for Defense Evasion/Obfuscation, 59.6% for Execution/Code Delivery, and 66.9% for Privilege/Tool/Authority Abuse. Its weakest mapped category is Integrity/Output Manipulation at 25.8%. Cisco and SkillSpector remain low-recall across all categories at their frozen primary gates.

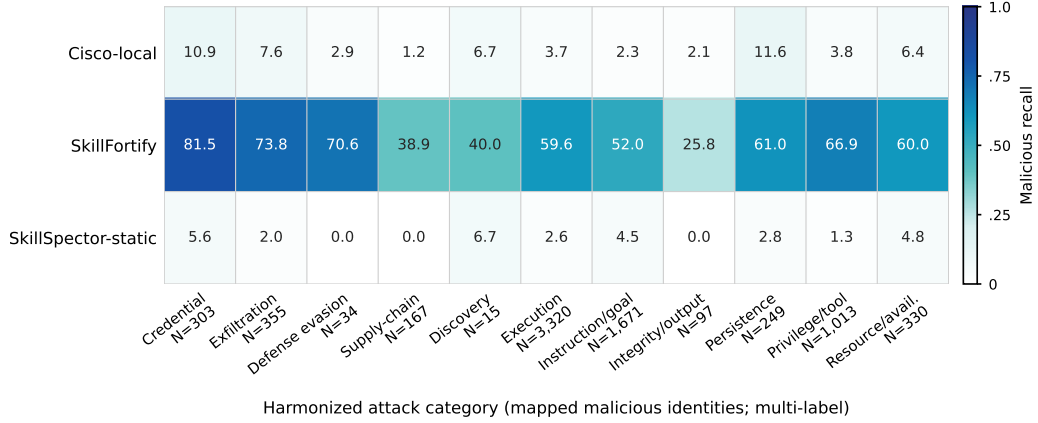


Figure 6: Malicious recall by harmonized attack category for the three frozen primary scanner configurations. Cell annotations are recall percentages; category sample sizes N are shown on the x-axis. The analysis is conditional on the 4,983 malicious identities with supported attack mappings, and categories are multi-label. Differences are descriptive and may reflect source composition as well as scanner behavior.

The stratified view should not be interpreted as a source-adjusted causal comparison. Attack categories are unevenly distributed across source datasets (Figure 2b), and some categories have small N (e.g., Discovery/Reconnaissance $N = 15$ and Defense Evasion/Obfuscation $N = 34$). We therefore use this analysis to describe coverage gaps, not to rank scanners by attack family independently of source composition.

J.5 COMPARABILITY BOUNDARY

The scanner study evaluates binary malicious-versus-benign detection on a common static artifact with fixed local configurations. It is not an adversarial-evasion/attack-success-rate experiment, and **SkillSpector-static** specifically uses its no-LLM mode. Results should therefore not be treated as numerically interchangeable with evaluations that use full packages, runtime behavior, cloud services, or LLM-backed scanner modes. The main conclusion is limited to the operational trade-off observed here: lower benign FPR can coincide with very low malicious recall, while a more sensitive scanner can incur substantial false positives.

K REPRESENTATIVE EXAMPLES

This appendix makes the benchmark units and audit decisions concrete without reproducing operational malicious payloads. Every example is anchored to the frozen benchmark identifiers used elsewhere in the paper. For malicious artifacts we report source-side attack descriptors, provenance/evidence metadata, hashes or family identifiers when useful, and a non-operational abstraction of the content. Commands, endpoints, credentials, executable helper logic, and other payload-bearing details are omitted. Benign examples may be named more directly because they do not carry an attack payload.

K.1 REPRESENTATIVE BENCHMARK UNITS

Table 49 illustrates four distinct ways a primary benchmark unit can arise. The examples are not intended to define the entire taxonomy; they show why intent, provenance, evidence, artifact unit, and lineage are recorded separately. In particular, “wild” does not imply stronger evidence than “constructed,” and a backdoored package is not treated as interchangeable with an injected synthetic variant.

Table 49: Representative primary benchmark units. Malicious content is summarized non-operationally; no payload command, endpoint, helper code, or executable instruction is reproduced.

Example	Frozen ID / source	Canonical metadata	Safe content abstraction
Wild malicious UASSB_00181999 SRC011	ASB04.002865 wild; Skill text; moderate/static	Upstream Snyk exfiltration case. The source descriptor identifies exfiltration behavior; transport command and destination are omitted.	
Injected malicious UASSB_00175991 SRC010	ASB04.006504 injected; Skill package; strong/constructed	SkillTrustBench case 00004 with a tool-hijack attack type; injected control-changing content is not reproduced.	
Backdoored malicious UASSB_00175105 SRC008	ASB04.006168 backdoored; Skill package; strong/constructed; derived lineage	SkillTrojan EHR/SQL backdoor example. The hidden malicious delta is omitted; frozen base linkage is unresolved.	
Benign reference UASSB_00181530 SRC011	ASB04.009716 wild; Skill text; moderate/static; independent lineage	ATR’s official-fetch reference case, retained as a high-confidence Main-benign unit under the same canonical schema.	

The malicious rows intentionally use safe abstractions and omit verbatim attack instructions. For example, the SRC011 record is retained as a wild malicious Skill because the frozen source identifies an exfiltration behavior under static evidence; the transport command and destination are not reproduced here. The SRC010 record is a constructed injected tool-hijack variant, while the SRC008 record is a constructed backdoored package. The benign SRC011 record demonstrates that the same canonical schema also preserves ordinary wild Skill artifacts as high-confidence reference negatives.

K.2 A STRUCTURAL-REUSE EXAMPLE

Table 50 shows two distinct normalized malicious units assigned to the same frozen operational structural family. Their exact and normalized hashes differ, so this is not an exact/normalized duplicate case. The family contains five normalized identities and spans SRC001/SRC005/SRC010 after source-set propagation. In the independent blind positive-validation sample, the pair was judged high-confidence “same structural template”: both retain the same YouTube-transcript summarization workflow and section ordering, while one variant adds a local prerequisite block. This is precisely the kind of scaffold reuse the structural partition is designed to capture.

Table 50: Representative non-duplicate structural-reuse pair from a frozen operational structural family. The pair was included in the blinded positive-validation set and judged high-confidence same structural template.

Canonical / bench- mark ID	Source-record hand	short-	Source	Normalized hash prefix	Similarity to representa- tive	Structural-review observation
UASSB_ 00007858 ASB04_ 001347	YouTube summarize (35o20)		SRC001	2c9012ef5e9f...	0.9967	Shared transcript-summarization setup, extraction, metadata, summarization, language, and option sections.
UASSB_ 00007934 ASB04_ 003626	yt-summarize		SRC001	7983b6100b3a...	0.9109	Same ordered workflow; the blind reviewer identified a local prerequisite addition as the main structural difference.

Family context. The current family contains five normalized identities associated with SRC001/SRC005/SRC010. The historical raw-record context contains repeated released artifacts; these counts describe structural reuse, not independent attacks or campaigns.

The example also illustrates the interpretation boundary emphasized in Appendix C.7: shared instructional structure does not establish a shared attacker, campaign, causal lineage, or attack mechanism. The family is an operational similarity control for evaluation, not an attack ontology.

K.3 A CROSS-LABEL CONFLICT GROUP

One conflict group from SRC006 (AgentTrap) makes the need for artifact-level conflict exclusion especially clear. Four source records share the same exact Skill hash and the same normalized hash, yet two source cases are canonicalized as benign test fixtures and two as malicious test fixtures. The shared base Skill is the same `xlsx` artifact; the case-level labels differ under the upstream runtime-fixture design. Table 51 lists the four records without reproducing any executable fixture or payload.

Table 51: Representative SRC006 cross-label identity conflict. All four records share exact Skill hash prefix `dd316db7785a...` and normalized hash prefix `6afac6531997...`; the conflicting group is excluded from the primary benchmark.

Canonical ID	Record	Intent	Evidence	Upstream case descrip- tor	Shared artifact context
UASSB_00107519	107	benign	strong / run- time	DIM7: output tamper- ing	Derived from the same upstream <code>xlsx</code> Skill identity; artifact text is identical at the frozen exact-hash level.
UASSB_00107520	108	benign	strong / run- time	DIM8: unauthorized disclosure	
UASSB_00107538	20	malicious	strong / run- time	DIM7: output tamper- ing	
UASSB_00107550	22	malicious	strong / run- time	DIM8: unauthorized disclosure	

At the primary static-artifact level, automatically choosing one side would collapse source context into an unsupported “correct” artifact label. We therefore exclude the entire conflicting identity group from the primary benchmark, while retaining its provenance and evidence in the audit layer. This example should not be read as proof that either upstream label is erroneous: the conflict may arise because the source label is attached to surrounding runtime context while the benchmark unit contains only the static Skill text.

K.4 A PAIRED SOURCE-CONDITIONED FALSE-POSITIVE EXAMPLE

The same frozen benign record can also behave differently under different training protocols. ASB04_007510 (UASSB_00181982) is the SRC011 wild benign Skill `real-wix--wix-cli-backend-event`. It is a moderate/static, independently identified benign reference unit that appears in both frozen test manifests. The seed-42 word TF-IDF + linear-SVM model predicts the record correctly under Random but flips it to malicious under Source-Disjoint, even though the evaluated static Skill unit itself is unchanged. Table 52 reports the frozen decision scores.

Table 52: Paired prediction for the same benign Skill under two frozen test protocols (seed-42 word TF-IDF + linear SVM). Positive decision scores predict malicious.

Protocol	True label	Prediction	Decision score	Interpretation
Random	benign	benign	-0.360	Correct classification for ASB04_007510.
Source-Disjoint	benign	malicious	+0.509	False positive on the same unchanged static Skill unit under source-held-out training.

Record metadata. UASSB_00181982, SRC011, `real-wix--wix-cli-backend-event`, `skill_md`, wild provenance, moderate/static benign evidence, independent lineage. The exact seed-42 decision scores are -0.360467 (Random) and +0.509328 (Source-Disjoint).

This paired example provides a descriptive comparison under two protocols. The model parameters and training distributions differ between protocols, and source identity bundles content style, provenance, construction process, and label composition. The example therefore supports the paper’s narrower claim of source-conditioned generalization sensitivity; it does not identify which source-associated factor caused the decision boundary to move.

L BENCHMARK RELEASE, SAFETY, AND GOVERNANCE

MALICIOUSSKILLBENCH is a security benchmark whose source registry contains both benign and malicious Agent Skill artifacts. Reproducibility therefore cannot be reduced to publishing every acquired byte in one archive. The release contract separates (i) the information needed to reproduce benchmark membership and evaluation, (ii) the public static-text representation of each benchmark identity, and (iii) source/package artifacts whose redistribution remains governed by recorded upstream terms. This appendix documents that contract and the maintenance rules for the frozen paper snapshot.

L.1 RELEASE PACKAGE AND REPRODUCIBILITY LAYERS

The public benchmark release is organized into complementary layers for identities, text, metadata, and reproducibility artifacts. Table 53 summarizes the release-facing contract. All 9,740 benchmark identities have a publicly readable representation. Exact frozen static Skill text is released for 9,735 identities (7,500 malicious and 2,235 benign); the remaining five malicious identities have sanitized public representations because their exact originals contain sensitive credential material. Source/package redistribution beyond these per-identity text representations remains subject to recorded upstream terms and benchmark-side safety constraints.

Table 53: Release layers for the frozen paper snapshot. Every primary identity has a public readable representation; source/package redistribution beyond that text layer remains source-specific as recorded in Appendix A.3.

Layer	Contents	Release form	Reproducibility role
Canonical registry	Canonical/source IDs, frozen revision, original/canonical label, provenance, evidence, label strength, artifact unit, lineage fields, license metadata	Public metadata	Reconstruct benchmark scope and source semantics
Identity and audit	Raw/exact identity hashes, normalized hashes, conflict flags, structural-family IDs, benchmark membership	Public metadata/hash	Verify identity, deduplication, reuse, and exclusions without executing artifacts
Primary static Skill text	Exact frozen text for 9,735 identities; sanitized readable representations for five credential-bearing malicious identities	Public text	Inspect all 9,740 primary identities while preserving the exact experimental text for 9,735
Evaluation	Master unit IDs, split assignments, leakage checks, sanitizer rules, detector configurations, metric/result tables	Public non-payload artifacts	Reproduce paper protocols and reported analyses
Redistributable Skill artifacts	Static Skill text/packages whose recorded source terms and benchmark-side policy permit republication	Source-specific	Enable direct local detector input where redistribution is allowed
Restricted-source reconstruction	Pinned source revision, source record identifiers, adapter/reacquisition instructions, and checksums for artifacts not republished	Adapter or metadata/hash only	Let users reacquire under upstream terms and verify local correspondence

The central design principle is that *benchmark reproducibility is not identical to full-package re-publication*. Stable canonical IDs, pinned source revisions, exact and normalized hashes, source labels, provenance/evidence fields, conflict decisions, structural-family assignments, split manifests, and checksums make the paper snapshot auditable while the public text layer makes every primary identity inspectable. The 186 accepted identities whose text came from author-provided historical research snapshots (153 from SRC002 and 33 from SRC004) now include their exact frozen static Skill text in the public release; their historical provenance remains recorded. Full upstream packages or auxiliary source content may still require source-specific reacquisition under the recorded terms.

L.2 STATIC-ONLY HANDLING AND HARMFUL-CONTENT MINIMIZATION

All acquired Skill contents are treated as untrusted data. Benchmark construction, deduplication, structural comparison, text-feature extraction, sanitization, and the reported detector experiments operate on static text/metadata only. The pipeline does not execute Skill code, helper scripts, installers, embedded shell commands, URLs, network requests, evaluation harnesses, or payloads. This non-execution rule applies regardless of whether an upstream source describes an artifact as benign, malicious, vulnerable, synthetic, or a test fixture.

The same principle constrains release documentation. Reproducibility tables describe artifact identity, provenance, evidence, labels, transformations, and evaluation outcomes without requiring execution of operational payloads. For five credential-bearing malicious records, the released text is sanitized to remove sensitive credential material while preserving a readable Skill representation; these five texts are not bit-for-bit copies of the frozen experimental inputs. This release-safety exception is distinct from the deterministic scaffold-sanitization control in Appendix H.2; that control is an analysis condition with no effect on benchmark release identity and provides no guarantee that harmful semantics have been removed.

L.3 LICENSING AND REDISTRIBUTION POLICY

Each source retains its own upstream license and redistribution constraints. Appendix A.3 records the frozen revision and benchmark-side policy for all 13 sources. The benchmark does not infer redistribution permission from the fact that a repository is publicly accessible, and it does not use a permissive benchmark-level license to supersede a more restrictive source license.

For source/package material beyond the public per-identity text layer, we apply the following precedence rule: the released representation is the most informative form that is both consistent with the recorded upstream terms and compatible with the benchmark’s safety policy. Practical cases include package redistribution where allowed, metadata/hash-only representation, or adapter-based

reconstruction from the upstream source. Any later discovery of changed or clarified upstream terms is handled as a release-governance event while preserving the frozen scientific snapshot.

L.4 INTENDED AND OUT-OF-SCOPE USES

Intended uses. MALICIOUSKILLBENCH is designed for defensive and measurement-oriented research: static malicious Agent Skill detection, source-conditioned generalization evaluation, dataset provenance auditing, duplicate/reuse analysis, label-consistency auditing, benign false-positive analysis, threat-stratified analysis, and reproducibility studies over the frozen source registry. The benchmark can also support development of new defensive models provided that comparisons report the benchmark version, split protocol, detector inputs, and class-aware metrics.

Out-of-scope uses. The benchmark is not intended as an execution suite for malicious Skills, a payload-generation or payload-improvement resource, an actor/campaign attribution dataset, or a prevalence estimate for the wider Agent Skill ecosystem. Operational structural families are not attack-mechanism or campaign labels (Appendix C.7), and Source-Disjoint is not a causal estimate of universal future-source performance (Appendix F.6). Likewise, performance of the static text baselines should not be interpreted as an upper bound on runtime, code-aware, behavioral, or multimodal security systems.

L.5 VERSIONING, CORRECTIONS, AND MAINTENANCE

The benchmark state used in this paper is frozen for reproducibility. Future maintenance must preserve that snapshot, including its members, labels, hashes, structural-family assignments, and split manifests. Table 54 specifies how common maintenance events should be handled.

Table 54: Maintenance and versioning contract. The paper snapshot remains immutable; scientifically material data changes create a new benchmark release while historical results remain tied to the frozen snapshot.

Maintenance event	Required action	Effect on frozen paper snapshot
Documentation/citation clarification	Record in changelog; do not alter data bytes, labels, hashes, or splits	None; paper numbers remain directly comparable
License/redistribution clarification	Update release representation and attribution; preserve the recorded historical policy in the archived snapshot	May change what is distributed, not the historical benchmark membership
Label, content, or conflict correction	Issue a new benchmark release; regenerate affected canonical metadata, hashes, conflicts, splits, and derived metrics as needed	The paper snapshot remains available and unchanged
Source addition/removal or newer upstream revision	Create a new release with explicit source/revision delta and fresh deduplication/conflict auditing	Not backfilled into the paper snapshot
Split/protocol redesign	Version the protocol and keep the original assignments available	Prior results retain their original protocol meaning
New detector or leaderboard entry	Record model, inputs, configuration, release, protocol, and class-aware metrics	Does not require a benchmark-data version change

Every benchmark result should therefore identify at least: the benchmark release, the evaluation protocol, the detector input representation, the model/configuration, and the reported metric set. New source additions or revised labels can be scientifically useful, but they define a new benchmark release and should be evaluated separately from the frozen paper snapshot. This prevents a continuously updated corpus from silently changing the meaning of previously reported numbers.

L.6 COMPACT BENCHMARK CARD

Table 55 summarizes the frozen scientific and release-facing contract in one place. It is intentionally a compact index; the source-, construction-, threat-, protocol-, and scanner-specific appendices above provide the full details.

Table 55: Compact benchmark card for the frozen MALICIOUSKILLBENCH paper snapshot. Counts refer to the canonicalized static benchmark unless a subset is stated explicitly.

Field	Frozen paper-snapshot value / contract
Source registry	13 public sources; 182,699 canonical registry records; 11 sources contribute at least one Core malicious Skill artifact.
Core malicious construction	8,414 raw artifacts → 7,562 exact-unique → 7,539 normalized-unique malicious identities.
Structural reuse control	4,588 operational structural families at the frozen 0.68 threshold; family IDs support structural-disjoint evaluation and reuse auditing, with no campaign-attribution semantics.
Cross-label conflicts	34 normalized malicious identities conflict with benign identities and are excluded from the primary benchmark under the frozen conflict policy.
Primary detection benchmark	9,740 normalized-unique Skills: 7,505 malicious + 2,235 Main-benign.
Threat-characterization coverage	4,983 malicious identities have harmonized multi-label attack mappings; 2,128 have conservative derived-impact mappings; 1,888 have both attack and impact mappings.
Frozen evaluation protocols	Random (6,818/974/1,948 train/dev/test); Source-Balanced Random (6,817/973/1,950); Malicious-Structural-Disjoint (6,818/974/1,948); Source-Disjoint (7,513/835/1,384), with 8 cross-boundary exclusions.
Detector suite	Three protocol-trained text baselines (word LR, word SVM, char SVM) plus three fixed off-the-shelf scanners (Cisco-local-behavioral, SkillFortify-offline, SkillSpector-static).
Artifact handling	Static analysis only; benchmark construction/evaluation never executes Skill instructions, helper code, installers, URLs, network actions, or payloads.
Public text release	All 9,740 identities have readable public representations; 9,735 provide exact frozen static Skill text (7,500 malicious + 2,235 benign), while five credential-bearing malicious identities provide sanitized representations only.
Release principle	Canonical metadata, hashes, split manifests, audit artifacts, and reproducibility material are public; full source/package redistribution beyond the per-identity text layer remains source-license- and safety-policy-specific.